

Số: 2453/QĐ-ĐHĐN

Đà Nẵng, ngày 26 tháng 6 năm 2025

QUYẾT ĐỊNH

**Ban hành Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng
của Đại học Đà Nẵng**

GIÁM ĐỐC ĐẠI HỌC ĐÀ NẴNG

Căn cứ Luật An toàn thông tin mạng ngày 19/11/2015;

Căn cứ Luật An ninh mạng ngày 12/6/2018;

Căn cứ Nghị định số 32/CP ngày 04/4/1994 của Chính phủ về việc thành lập Đại học Đà Nẵng;

Căn cứ Nghị định số 85/2016/NĐ-CP ngày 01/7/2016 của Chính phủ về bảo đảm an toàn hệ thống thông tin theo cấp độ;

Căn cứ Nghị định số 142/2016/NĐ-CP ngày 14/10/2016 của Chính phủ về ngăn chặn xung đột thông tin trên mạng;

Căn cứ Nghị định số 53/2022/NĐ-CP ngày 15/8/2022 của Chính phủ về việc quy định chi tiết một số điều của Luật An ninh mạng;

Căn cứ Nghị định số 13/2023/NĐ-CP ngày 17/4/2023 của Chính phủ về bảo vệ dữ liệu cá nhân;

Căn cứ Thông tư số 20/2017/TT-BTTTT ngày 12/9/2017 của Bộ Thông tin và Truyền thông quy định về điều phối, ứng cứu sự cố an toàn thông tin mạng trên toàn quốc;

Căn cứ Thông tư số 31/2017/TT-BTTTT ngày 15/11/2017 của Bộ Thông tin và Truyền thông quy định hoạt động giám sát an toàn hệ thống thông tin;

Căn cứ Thông tư số 12/2022/TT-BTTTT ngày 12/8/2022 của Bộ Thông tin và Truyền thông quy định chi tiết và hướng dẫn một số điều của Nghị định số 85/2016/NĐ-CP ngày 01/7/2016 của Chính phủ về bảo đảm an toàn hệ thống thông tin theo cấp độ;

Căn cứ Công văn số 5722/BGDĐT-CNTT ngày 13/10/2023 của Bộ Giáo dục và Đào tạo về việc thực hiện Nghị định của Chính phủ Quy định chi tiết một số điều của Luật An ninh mạng;

Căn cứ Thông tư số 10/2020/TT-BGDĐT ngày 14/5/2020 của Bộ trưởng Bộ Giáo dục và Đào tạo về việc ban hành Quy chế tổ chức và hoạt động của đại học vùng và các cơ sở giáo dục đại học thành viên;

Căn cứ Nghị quyết số 08/NQ-HĐĐH ngày 12/7/2021 của Hội đồng Đại học Đà Nẵng về việc ban hành Quy chế tổ chức và hoạt động của Đại học Đà Nẵng và Nghị quyết số 13/NQ-HĐĐH ngày 07/9/2021 của Hội đồng Đại học Đà Nẵng về việc sửa đổi, bổ sung một số điều của Quy chế tổ chức và hoạt động của Đại học Đà Nẵng;

Theo đề nghị của Giám đốc Trung tâm Công nghệ thông tin và Học liệu số, Đại học Đà Nẵng.

QUYẾT ĐỊNH:

Điều 1. Ban hành kèm theo Quyết định này “Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng của Đại học Đà Nẵng”.

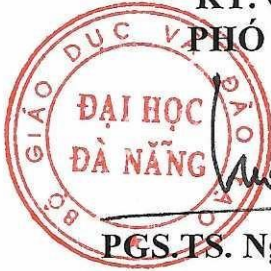
Điều 2. Quyết định này có hiệu lực kể từ ngày ký.

Điều 3. Chánh Văn phòng, Hiệu trưởng các trường đại học thành viên, Giám đốc Trung tâm Công nghệ thông tin và Học liệu số, Thủ trưởng các đơn vị thuộc, trực thuộc Đại học Đà Nẵng và các cá nhân, đơn vị liên quan căn cứ Quyết định thi hành. *Heq*

Nơi nhận:

- Như Điều 3;
- Giám đốc (để b/c).
- Lưu: VT, CNTTLS.

KT. GIÁM ĐỐC
PHÓ GIÁM ĐỐC



PGS.TS. Nguyễn Mạnh Toàn

QUY CHẾ

Bảo đảm an toàn thông tin mạng và an ninh mạng của Đại học Đà Nẵng
(Ban hành kèm theo Quyết định số 2453/QĐ-ĐHĐN ngày 26/6/2025
của Giám đốc Đại học Đà Nẵng)

Chương I

QUY ĐỊNH CHUNG

Điều 1. Phạm vi và đối tượng áp dụng

1. Phạm vi

Quy chế này quy định về bảo đảm an toàn thông tin mạng (ATTT) và an ninh mạng (ANM) cho các hoạt động ứng dụng công nghệ thông tin (CNTT), chuyển đổi số (CDS) của Đại học Đà Nẵng (ĐHĐN).

2. Đối tượng áp dụng

Quy chế này áp dụng đối với các trường đại học thành viên (ĐHTV), các đơn vị thuộc và trực thuộc ĐHĐN (gọi chung là các đơn vị).

Cá nhân là viên chức, người lao động của các trường ĐHTV, các đơn vị thuộc, trực thuộc ĐHĐN và các tổ chức, cá nhân khác tham gia vào hoạt động ứng dụng CNTT, CDS của ĐHĐN.

Điều 2. Giải thích từ ngữ

Trong Quy chế này, các từ ngữ dưới đây được hiểu như sau:

1. *Mạng* là môi trường trong đó thông tin được cung cấp, truyền đưa, thu thập, xử lý, lưu trữ và trao đổi thông qua mạng viễn thông và mạng máy tính.

2. *Không gian mạng* là mạng lưới kết nối của cơ sở hạ tầng công nghệ thông tin, bao gồm mạng viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, cơ sở dữ liệu; là nơi con người thực hiện các hành vi xã hội không bị giới hạn bởi không gian và thời gian.

3. *An toàn thông tin mạng* là sự bảo vệ thông tin, hệ thống thông tin trên mạng tránh bị truy nhập, sử dụng, tiết lộ, gián đoạn, sửa đổi hoặc phá hoại trái phép nhằm bảo đảm tính nguyên vẹn, tính bảo mật và tính khả dụng của thông tin.

4. *An ninh mạng* là sự bảo đảm hoạt động trên không gian mạng không gây phương hại đến an ninh quốc gia, trật tự an toàn xã hội, bí mật nhà nước, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân.

5. *Hệ thống thông tin* là tập hợp phần cứng, phần mềm và cơ sở dữ liệu được thiết lập phục vụ mục đích tạo lập, cung cấp, truyền đưa, thu thập, xử lý, lưu trữ và trao đổi thông tin trên mạng.

6. *Chủ quản hệ thống thông tin* là cơ quan, tổ chức, cá nhân có thẩm quyền quản lý trực tiếp đối với hệ thống thông tin; là cấp có thẩm quyền quyết định đầu tư dự án xây dựng, thiết lập, nâng cấp, mở rộng hệ thống thông tin đó.

7. *Đơn vị vận hành hệ thống thông tin* là cơ quan, tổ chức được chủ quản hệ thống thông tin giao nhiệm vụ vận hành hệ thống thông tin.

8. *Đơn vị chuyên trách về an toàn thông tin* là đơn vị có chức năng, nhiệm vụ bảo đảm an toàn thông tin của chủ quản hệ thống thông tin.

9. *Sự cố an toàn thông tin mạng* là việc thông tin, hệ thống thông tin bị gây nguy hại, ảnh hưởng tới tính nguyên vẹn, tính bảo mật hoặc tính khả dụng.

10. *Rủi ro an toàn thông tin mạng* là những nhân tố chủ quan hoặc khách quan có khả năng ảnh hưởng tới trạng thái an toàn thông tin mạng.

11. *Đánh giá rủi ro an toàn thông tin mạng* là việc phát hiện, phân tích, ước lượng mức độ tổn hại, mối đe dọa đối với thông tin, hệ thống thông tin.

12. *Quản lý rủi ro an toàn thông tin mạng* là việc đưa ra các biện pháp nhằm giảm thiểu rủi ro an toàn thông tin mạng.

13. *Phần mềm độc hại* là phần mềm có khả năng gây ra hoạt động không bình thường cho một phần hay toàn bộ hệ thống thông tin hoặc thực hiện sao chép, sửa đổi, xóa bỏ trái phép thông tin lưu trữ trong hệ thống thông tin.

Điều 3. Nguyên tắc bảo đảm ATTT, ANM

1. Bảo đảm ATTT, ANM tuân thủ nguyên tắc được quy định tại Điều 4 Luật An toàn thông tin mạng và Điều 4 Luật An ninh mạng.

2. Trách nhiệm bảo đảm ATTT, ANM gắn với trách nhiệm của người đứng đầu đơn vị và cá nhân trực tiếp liên quan.

3. Xử lý sự cố ATTT, ANM phải phù hợp với trách nhiệm, quyền hạn và bảo đảm lợi ích hợp pháp của cơ quan, đơn vị, cá nhân liên quan và theo quy định của pháp luật.

4. Việc quản lý, sử dụng và bảo đảm ANM, mạng máy tính nội bộ có lưu trữ, truyền đưa bí mật nhà nước phải tuân thủ theo Quyết định số 2763/QĐ-ĐHĐN ngày 14/8/2020 của Giám đốc ĐHĐN về việc ban hành Quy chế về công tác bảo vệ bí mật Nhà nước tại ĐHĐN.

5. Tuân thủ các quy định và hướng dẫn về bảo đảm ATTT, ANM của cơ quan có thẩm quyền. Trường hợp có văn bản, quy định cập nhật, thay thế hoặc quy định khác tại văn bản quy phạm pháp luật, quyết định của cấp có thẩm quyền cao hơn thì áp dụng quy định tại văn bản đó.

Điều 4. Các hành vi nghiêm cấm

1. Các hành vi bị nghiêm cấm thực hiện theo quy định tại Điều 7 Luật An toàn thông tin mạng và Điều 8 Luật An ninh mạng.

2. Vi phạm các quy định, quy chế, quy trình về quản lý, vận hành, sử dụng, bảo đảm ATTT, ANM đối với hạ tầng kỹ thuật và hệ thống thông tin (HTTT) của ĐHĐN.

3. Tự ý đăng lên, tải về, chia sẻ dưới mọi hình thức các dữ liệu, tài liệu, số liệu nội bộ, những văn bản chưa được cấp có thẩm quyền công khai lên mạng internet và các phương tiện thông tin đại chúng khác.

4. Tự ý đấu nối thiết bị mạng, thiết bị cấp phát địa chỉ mạng, thiết bị phát sóng như điểm truy cập không dây của cá nhân vào mạng nội bộ.

5. Tự ý thay đổi, lắp mới, tháo đổi thành phần của máy tính phục vụ công việc; gỡ bỏ biện pháp bảo đảm ATTT, ANM cài đặt trên thiết bị công nghệ thông tin phục vụ công việc.

6. Tự ý phát sóng các thiết bị cá nhân trong khu vực (đã thông báo không được phép phát sóng) gây nhiễu sóng hoặc ảnh hưởng đến hệ thống của cơ quan, đơn vị.

Chương II

BẢO ĐẢM AN TOÀN THÔNG TIN MẠNG

Điều 5. Phân cấp thực hiện bảo đảm ATTT

1. Chủ quản HTTT

a) ĐHĐN là chủ quản HTTT đối với các HTTT do ĐHĐN đầu tư phát triển, nâng cấp, mở rộng và các HTTT khác được giao.

b) Các trường ĐHTV, các đơn vị trực thuộc ĐHĐN là chủ quản HTTT do đơn vị đầu tư phát triển, nâng cấp, mở rộng HTTT và các HTTT khác được giao.

2. Đơn vị vận hành HTTT

a) Trung tâm Công nghệ thông tin và Học liệu số, ĐHĐN (sau đây viết tắt là Trung tâm IDC) là đơn vị vận hành các HTTT do ĐHĐN làm chủ quản HTTT.

b) Các trường ĐHTV, các đơn vị trực thuộc ĐHĐN chịu trách nhiệm phân công đơn vị vận hành HTTT của đơn vị mình.

3. Đơn vị chuyên trách về ATTT

a) Trung tâm IDC là đơn vị chuyên trách về ATTT cho các HTTT do ĐHĐN làm chủ quản HTTT.

b) Các trường ĐHTV thành lập hoặc chỉ định bộ phận chuyên trách về ATTT tại đơn vị mình.

c) Các đơn vị trực thuộc ĐHĐN, tùy vào tình hình nguồn lực có thể thành lập/chỉ định bộ phận chuyên trách về ATTT tại đơn vị mình hoặc đề nghị ĐHĐN tham gia hỗ trợ.

4. Đơn vị chuyên trách về ứng cứu sự cố ATTT

a) Trung tâm IDC đảm nhiệm vai trò đơn vị chuyên trách ứng cứu sự cố ATTT của ĐHĐN, là đơn vị làm đầu mối liên hệ, phối hợp với các cơ quan, tổ chức có thẩm quyền thực hiện việc tiếp nhận và xử lý các sự cố về ATTT của ĐHĐN.

b) Đơn vị chuyên trách về ATTT của các trường ĐHTV, các đơn vị trực thuộc ĐHĐN đảm nhiệm vai trò đơn vị chuyên trách ứng cứu sự cố ATTT tại đơn vị, làm đầu mối liên hệ, phối hợp với các cơ quan, tổ chức có thẩm quyền thực hiện việc tiếp nhận và xử lý các sự cố về ATTT tại đơn vị.

Điều 6. Trách nhiệm của các bên liên quan trong việc bảo đảm ATTT

1. Đối với chủ quản HTTT

a) Thực hiện trách nhiệm quy định tại Điều 20 Nghị định 85/2016/NĐ-CP ngày 01/7/2016 của Chính phủ về bảo đảm an toàn HTTT theo cấp độ.

b) Quy định rõ vai trò và trách nhiệm của từng viên chức, người lao động được phân công tham gia công tác bảo đảm ATTT tại đơn vị.

c) Tổ chức triển khai các biện pháp và quy trình quản lý tài khoản, bao gồm: cấp mới, phân quyền truy cập, thu hồi tài khoản và quản lý toàn bộ tài sản liên quan đến HTTT đối với viên chức, người lao động thuộc phạm vi quản lý.

d) Thường xuyên rà soát, kiểm tra quyền truy cập của viên chức, người lao động đối với HTTT, nhằm bảo đảm quyền truy cập phù hợp với vị trí công tác và nhiệm vụ được giao.

đ) Kịp thời thực hiện việc thay đổi hoặc thu hồi quyền truy cập và tài sản CNTT đối với viên chức, người lao động khi có sự thay đổi vị trí công tác hoặc chấm dứt công việc tại đơn vị.

2. Đối với đơn vị vận hành HTTT

a) Thực hiện xác định cấp độ an toàn hệ thống thông tin theo quy định tại Điều 14 Nghị định 85/2016/NĐ-CP.

b) Thực hiện bảo vệ HTTT theo quy định của pháp luật và hướng dẫn, tiêu chuẩn, quy chuẩn an toàn thông tin.

c) Định kỳ đánh giá hiệu quả của các biện pháp bảo đảm an toàn thông tin, báo cáo chủ quản HTTT điều chỉnh nếu cần thiết.

d) Định kỳ hoặc đột xuất báo cáo công tác thực thi bảo đảm an toàn HTTT theo yêu cầu của chủ quản HTTT hoặc cơ quan quản lý nhà nước chuyên ngành có thẩm quyền.

đ) Phối hợp và thực hiện đầy đủ các yêu cầu của cơ quan chức năng có thẩm quyền trong công tác bảo đảm ATTT.

3. Đối với đơn vị chuyên trách về ATTT

a) Tham mưu, tổ chức thực thi, đôn đốc, kiểm tra, giám sát công tác bảo đảm ATTT.

b) Thẩm định, phê duyệt hoặc cho ý kiến về mặt chuyên môn đối với hồ sơ đề xuất cấp độ theo thẩm quyền quy định tại khoản 1, khoản 2 Điều 12 và khoản 5 Điều 15 Nghị định 85/2016/NĐ-CP.

c) Thực hiện trách nhiệm do chủ quản HTTT phân công.

4. Đối với viên chức, người lao động đang trong quá trình công tác

a) Tuân thủ các quy định, hướng dẫn về bảo đảm ATTT, ANM và các quy định của pháp luật liên quan, phù hợp với vị trí công tác được phân công.

b) Khi phát hiện nguy cơ mất an toàn thông tin hoặc dấu hiệu xảy ra sự cố an toàn thông tin, viên chức, người lao động có trách nhiệm kịp thời báo cáo với đơn vị hoặc

cán bộ chuyên trách về an toàn thông tin để được xem xét, tham mưu, tổ chức các biện pháp ngăn chặn, xử lý và khắc phục sự cố.

c) Tham gia đầy đủ các lớp tập huấn, đào tạo, bồi dưỡng về ATTT do đơn vị hoặc cơ quan cấp trên tổ chức.

d) Quản lý, sử dụng đúng mục đích các trang thiết bị CNTT được đơn vị giao; không sử dụng thiết bị CNTT cá nhân để kết nối, truy cập vào HTTT nội bộ nếu chưa được sự cho phép của đơn vị chủ quản hệ thống.

đ) Chỉ được cài đặt các phần mềm hợp lệ, có bản quyền và được phép sử dụng trên máy tính do đơn vị cung cấp; trước khi sao chép dữ liệu, mở tập tin hoặc kết nối bất kỳ thiết bị lưu trữ di động nào vào máy tính, cần thường xuyên sử dụng các phần mềm chuyên dụng để kiểm tra, đảm bảo an toàn thông tin và phòng chống mã độc.

e) Không truy cập hoặc mở các trang tin, thư điện tử không rõ nguồn gốc; hạn chế sử dụng tính năng lưu hoặc tự động điền mật khẩu.

g) Bảo mật tài khoản truy cập thông tin; không chia sẻ mật khẩu hoặc thông tin cá nhân; đặt mật khẩu mạnh (tối thiểu 8 ký tự, bao gồm chữ thường, chữ in hoa, số và ký tự đặc biệt như @, #, !) và thay đổi định kỳ 3 đến 6 tháng 1 lần.

h) Chấp hành nghiêm các quy định, quy chế, quy trình về đảm bảo ATTT của đơn vị; thực hiện đầy đủ các hướng dẫn, khuyến cáo của đơn vị hoặc cán bộ chuyên trách CNTT, ATTT.

i) Bảo vệ thông tin cá nhân của bản thân; tuân thủ quy định pháp luật về cung cấp thông tin cá nhân khi sử dụng dịch vụ trực tuyến; bảo đảm an toàn thông tin đối với dữ liệu do mình trực tiếp xử lý theo quy định tại Nghị định số 13/2023/NĐ-CP ngày 17/4/2023 của Chính phủ về bảo vệ dữ liệu cá nhân.

k) Thực hiện quy tắc ứng xử trên mạng theo Điều 5 của Quyết định số 874/QĐ-BTTTT ngày 17/6/2021 của Bộ Thông tin và Truyền thông về việc ban hành bộ quy tắc ứng xử trên mạng xã hội.

5. Đối với viên chức, người lao động nghỉ việc hoặc thay đổi công việc

a) Bàn giao đầy đủ công việc, tài khoản truy cập HTTT, cũng như các tài sản CNTT cho đơn vị trước khi nghỉ việc hoặc chuyển công tác.

b) Cam kết bảo mật các thông tin liên quan đến đơn vị và không tiết lộ ra bên ngoài dưới mọi hình thức.

Điều 7. Xây dựng Hồ sơ đề xuất cấp độ và triển khai phương án bảo đảm an toàn thông tin theo cấp độ

1. Chủ quản HTTT chỉ đạo đơn vị vận hành HTTT thực hiện xác định cấp độ HTTT và xây dựng phương án đảm bảo ATTT phù hợp với cấp độ HTTT theo quy định tại Nghị định 85/2016/NĐ-CP, Thông tư số 12/2022/TT-BTTTT ngày 12/8/2022 của Bộ Thông tin và Truyền thông quy định chi tiết và hướng dẫn một số điều của Nghị định số 85/2016/NĐ-CP và hướng dẫn chi tiết tại Tiêu chuẩn quốc gia TCVN 11930:2017: Công nghệ thông tin - các kỹ thuật an toàn - yêu cầu cơ bản về an toàn hệ thống thông tin theo cấp độ, gồm các nội dung sau:

a) Nguyên tắc bảo đảm an toàn HTTT theo cấp độ và nguyên tắc xác định cấp độ HTTT thực hiện theo các nguyên tắc quy định tại Điều 4, Điều 5 của Nghị định 85/2016/NĐ-CP.

b) Tiêu chí, thẩm quyền, trình tự, thủ tục xác định cấp độ HTTT thực hiện theo quy định từ Điều 6 đến Điều 14 của Nghị định 85/2016/NĐ-CP và tại Điều 6 của Thông tư số 12/2022/TT-BTTTT (Hướng dẫn xác định cấp độ HTTT tại Phụ lục I kèm theo Quy chế này).

c) Hồ sơ đề xuất cấp độ, thẩm định hồ sơ đề xuất cấp độ, hồ sơ phê duyệt đề xuất cấp độ HTTT thực hiện theo quy định tại Điều 15, Điều 16, Điều 17 của Nghị định 85/2016/NĐ-CP và Điều 8 của Thông tư số 12/2022/TT-BTTTT (Hướng dẫn xây dựng Hồ sơ đề xuất cấp độ tại Phụ lục II kèm theo Quy chế này, Hướng dẫn các bước thẩm định, phê duyệt hồ sơ đề xuất cấp độ tại Phụ lục III kèm theo Quy chế này, Hướng dẫn thẩm định hồ sơ đề xuất cấp độ HTTT tại Phụ lục IV kèm theo Quy chế này).

d) Phương án bảo đảm an toàn HTTT theo cấp độ đáp ứng theo yêu cầu quy định tại Điều 19 của Nghị định 85/2016/NĐ-CP, Điều 10 của Thông tư 12/2022/TT-BTTTT và hướng dẫn chi tiết tại tiêu chuẩn quốc gia TCVN 11930:2017.

2. Chủ quản HTTT hoặc đơn vị được ủy quyền quản lý trực tiếp HTTT tổ chức triển khai phương án bảo đảm an toàn HTTT sau khi hồ sơ đề xuất cấp độ hoặc phương án bảo đảm an toàn hệ thống được phê duyệt.

3. Đơn vị chuyên trách về ATTT chịu trách nhiệm giám sát việc triển khai các phương án bảo đảm an toàn thông tin đã được phê duyệt.

Điều 8: Bảo đảm ATTT trong thiết kế, xây dựng HTTT

1. Khi triển khai thiết kế, xây dựng HTTT chủ quản HTTT có trách nhiệm thực hiện một số nội dung sau:

a) Có tài liệu mô tả quy mô, phạm vi và đối tượng sử dụng, khai thác, quản lý vận hành HTTT; tài liệu mô tả thiết kế và các thành phần của HTTT; tài liệu mô tả phương án bảo đảm an toàn thông tin theo cấp độ; tài liệu mô tả phương án lựa chọn giải pháp công nghệ bảo đảm ATTT.

b) Đánh giá lại tính phù hợp của phương án đảm bảo ATTT khi có thay đổi thiết kế, xây dựng HTTT so với phương án trước khi thay đổi.

c) Xây dựng phương án quản lý và bảo vệ hồ sơ thiết kế HTTT.

d) Có bộ phận chuyên môn hoặc tổ chuyên gia chịu trách nhiệm đánh giá hồ sơ thiết kế HTTT và các biện pháp bảo đảm an toàn thông tin trước khi triển khai thực hiện.

đ) Hệ thống phải bảo đảm mật khẩu của người dùng có độ bảo mật cao, với yêu cầu bắt buộc gồm tối thiểu 8 ký tự và phải có đầy đủ các thành phần: chữ cái viết hoa, chữ cái viết thường, chữ số và ký tự đặc biệt.

e) Ứng dụng khi thiết kế và xây dựng phải đảm bảo xác thực người dùng theo các tiêu chí: có kiểm tra và phân quyền người dùng khi truy cập hệ thống; mã hóa thông tin xác thực; bảo vệ mật khẩu; giới hạn số lần đăng nhập sai liên tiếp; ưu tiên chứng thực tập trung; không khuyến khích đăng nhập tự động với ứng dụng và dịch vụ xử lý dữ liệu quan trọng.

2. Khi phát triển phần mềm thuê khoán trong quá trình thiết kế, xây dựng HTTT chủ quản HTTT thực hiện một số nội dung sau:

- a) Có biên bản, hợp đồng và các cam kết đối với bên thuê khoán các nội dung liên quan đến việc phát triển phần mềm thuê khoán.
- b) Kiểm thử phần mềm trên môi trường thử nghiệm trước khi đưa vào sử dụng.
- c) Kiểm tra, đánh giá ATTT, trước khi đưa vào sử dụng, khi thay đổi mã nguồn, kiến trúc phần mềm cần thực hiện kiểm tra, đánh giá lại ATTT cho phần mềm.
- d) Việc cung cấp mã nguồn phần mềm, bảo đảm tính bí mật và bản quyền của phần mềm dựa trên hợp đồng giữa các bên theo điểm a khoản 2 của Điều này.

3. Trước khi sử dụng HTTT, chủ quản HTTT cần phải thử nghiệm và nghiệm thu hệ thống theo những yêu cầu sau:

- a) Có nội dung, kế hoạch, quy trình thử nghiệm và nghiệm thu hệ thống. Nội dung, kế hoạch và quy trình nghiệm thu hệ thống được thực hiện theo Thông tư số 16/2024/TT-BTTTT ngày 30/12/2024 của Bộ Thông tin và Truyền thông quy định chi tiết nội dung công tác triển khai, giám sát công tác triển khai, nghiệm thu đối với dự án đầu tư ứng dụng công nghệ thông tin; xác định yêu cầu về chất lượng dịch vụ và các nội dung đặc thù của hợp đồng thuê dịch vụ đối với thuê dịch vụ công nghệ thông tin theo yêu cầu riêng.
- b) Có bộ phận có trách nhiệm thực hiện thử nghiệm và nghiệm thu hệ thống.
- c) Có đơn vị độc lập (bên thứ ba) hoặc bộ phận độc lập thuộc đơn vị thực hiện tư vấn và giám sát quá trình thử nghiệm và nghiệm thu hệ thống.
- d) Có báo cáo nghiệm thu được xác nhận của bộ phận chuyên trách và phê duyệt của chủ quản HTTT trước khi đưa vào sử dụng.

Điều 9. Bảo đảm ATTT trong vận hành HTTT

Khi vận hành HTTT, chủ quản HTTT thực hiện một số nội dung sau:

1. Bảo đảm ATTT đối với Máy chủ và Trung tâm dữ liệu/Phòng máy chủ

a) Bảo đảm ATTT đối với Máy chủ

- Thiết lập chính sách kiểm tra trên máy chủ nhằm bảo đảm việc xác thực người dùng khi truy cập, quản lý và sử dụng máy chủ.
- Thực hiện thay đổi các tài khoản mặc định hoặc vô hiệu hóa nếu không sử dụng nhằm hạn chế nguy cơ mất an toàn thông tin.
- Thiết lập cơ chế kiểm soát truy cập hệ thống, giới hạn địa chỉ mạng được phép kết nối khi quản trị máy chủ từ xa.
- Cấu hình giới hạn thời gian chờ để tự động đóng phiên kết nối khi không có yêu cầu từ người dùng; thực hiện thay đổi cổng quản trị mặc định nhằm nâng cao mức độ bảo mật.
- Thực hiện ghi nhật ký đầy đủ hoạt động truy cập, các tác động vào máy chủ, lỗi phát sinh, các sự cố nhằm phục vụ công tác giám sát, kiểm tra và điều tra khi cần thiết.

- Áp dụng các biện pháp phòng chống xâm nhập trái phép như: loại bỏ các tài khoản không sử dụng hoặc không còn hợp lệ; cấu hình tường lửa của hệ điều hành và hệ thống để ngăn chặn truy cập trái phép.

- Vô hiệu hóa các giao thức, các cổng kết nối mạng không sử dụng; thường xuyên cập nhật bản vá, xử lý điểm yếu về an toàn thông tin cho hệ điều hành và dịch vụ hệ thống.

- Thực hiện cập nhật, nâng cấp và kiểm tra bảo mật máy chủ trước khi đưa vào vận hành chính thức.

- Triển khai biện pháp phòng chống phần mềm độc hại, bao gồm: cài đặt phần mềm chống mã độc, thiết lập cơ chế cập nhật cơ sở dữ liệu tự động, kiểm tra và quét mã độc đối với các phần mềm trước khi cài đặt.

- Thực hiện quản lý tập trung đối với các phần mềm phòng, chống mã độc được cài đặt trên hệ thống máy chủ và thiết bị đầu cuối của người sử dụng trong toàn hệ thống.

- Thực hiện sao lưu dữ liệu và hệ điều hành trước khi tiến hành xóa, đồng thời áp dụng các biện pháp kỹ thuật để bảo đảm dữ liệu không thể phục hồi sau khi xóa.

- Xây dựng phương án xóa toàn bộ thông tin và dữ liệu trên máy chủ khi thực hiện chuyển giao hoặc thay đổi mục đích sử dụng.

- Ưu tiên sử dụng phần mềm hệ điều hành có bản quyền hoặc phần mềm mã nguồn mở tin cậy được phổ biến rộng rãi trong nước và quốc tế. Có tài liệu liệt kê đầy đủ các phần mềm hệ thống cài đặt trên máy chủ, tài liệu hướng dẫn cài đặt các phần trên máy chủ, đồng thời cấu hình vùng mạng quản trị riêng biệt và giới hạn địa chỉ IP được phép truy cập quản trị.

- Trường hợp sử dụng loại hình thuê dịch vụ máy chủ ảo ở bên ngoài thì trong hợp đồng với nhà cung cấp dịch vụ máy chủ ảo, cần xác định rõ quyền và trách nhiệm của các bên, đặc biệt là về bảo mật và an toàn dữ liệu đồng thời yêu cầu nhà cung cấp dịch vụ cung cấp đầy đủ báo cáo và nhật ký truy vết phục vụ công tác kiểm tra, giám sát và xác minh các hoạt động truy cập, xử lý dữ liệu trên hệ thống.

b) Bảo đảm ATTT đối với Trung tâm dữ liệu/Phòng máy chủ

- Trang bị đầy đủ hệ thống phòng cháy, chữa cháy theo đúng tiêu chuẩn kỹ thuật hiện hành; hệ thống điều hòa không khí phù hợp với quy mô và điều kiện vận hành; hệ thống lưu điện (UPS) dự phòng có công suất phù hợp để đảm bảo an toàn dữ liệu cho máy chủ, các thiết bị lưu trữ chuyên dụng khi có sự cố mất điện..

- Có biện pháp bảo vệ vật lý và phương án dự phòng nhằm phòng chống các nguy cơ mất an toàn thông tin do mất cắp, cháy nổ, ngập lụt, động đất hoặc các thảm họa khác do thiên nhiên hoặc con người gây ra. Đồng thời, xây dựng, triển khai phương án khôi phục hệ thống sau thảm họa bảo đảm tính sẵn sàng và liên tục của hệ thống.

- Thiết lập cơ chế bảo vệ, giám sát, phát hiện xâm nhập, kiểm soát can thiệp vật lý đối với các thiết bị mạng, thiết bị bảo mật như tường lửa, thiết bị định tuyến, máy chủ và hệ thống lưu trữ. Việc truy cập, kết nối vật lý phải được kiểm soát chặt chẽ, phù hợp với vai trò, trách nhiệm của từng cá nhân, đơn vị.

- Trang bị hệ thống camera giám sát hoạt động liên tục 24 giờ mỗi ngày, 7 ngày mỗi tuần (24/7), bảo đảm phạm vi giám sát toàn bộ khu vực. Dữ liệu hình ảnh từ hệ

thống giám sát phải được lưu trữ tối thiểu trong thời gian 60 ngày để phục vụ công tác kiểm tra, giám sát và xử lý sự cố khi cần thiết.

Xây dựng và ban hành quy chế, quy định, quy trình khai thác, vận hành Trung tâm dữ liệu/Phòng máy chủ phù hợp với quy mô hệ thống và yêu cầu nghiệp vụ. Quy định phải cụ thể hóa trách nhiệm của từng bộ phận, cá nhân trong quản lý, vận hành và bảo vệ an toàn thông tin.

2. Bảo đảm ATTT đối với hệ thống mạng

a) Hệ thống mạng phải được thiết kế phân vùng theo chức năng phù hợp với cấp độ của hệ thống thông tin theo quy định tại Thông tư số 12/2022/TT-BTTTT và hướng dẫn chi tiết tại Tiêu chuẩn quốc gia TCVN 11930:2017.

b) Thiết lập các cơ chế kiểm soát truy cập từ bên ngoài mạng, bảo đảm chỉ cho phép sử dụng các kết nối mạng an toàn khi truy cập vào thông tin nội bộ hoặc quản trị hệ thống từ các mạng bên ngoài, bao gồm cả mạng Internet. Việc truy cập từ bên ngoài vào hệ thống phải được kiểm soát theo từng dịch vụ, ứng dụng cụ thể; phân quyền truy cập phải được xác định rõ ràng theo từng người dùng hoặc nhóm người dùng, căn cứ theo yêu cầu nghiệp vụ và quản lý của đơn vị.

c) Thiết lập kiểm soát truy cập từ bên trong hệ thống mạng, bảo đảm chỉ cho phép truy cập ra bên ngoài đến các ứng dụng, dịch vụ theo yêu cầu nghiệp vụ. Đồng thời, cần có giải pháp kiểm soát quyền truy cập của người dùng đối với các máy chủ và dịch vụ nội bộ trên cơ sở chức năng và chính sách quản lý của đơn vị.

d) Thiết lập chức năng ghi nhận và lưu trữ nhật ký hệ thống trên các thiết bị trong mạng. Toàn bộ nhật ký hệ thống phải được lưu trữ và quản lý tập trung, bảo đảm sẵn sàng cho công tác theo dõi, giám sát, kiểm tra và điều tra an toàn thông tin khi cần thiết.

đ) Xây dựng và triển khai phương án phòng chống xâm nhập, bảo vệ các phân vùng mạng trong hệ thống, bảo đảm năng lực hệ thống đáp ứng yêu cầu về quy mô người dùng, dịch vụ và ứng dụng được cung cấp trên toàn hệ thống.

e) Triển khai phương án phòng chống phần mềm độc hại trên môi trường mạng; định kỳ cập nhật cơ sở dữ liệu nhận diện mã độc cho các hệ thống phòng chống phần mềm độc hại.

g) Thiết lập giải pháp bảo vệ các thiết bị đầu cuối, đường truyền dữ liệu, kết nối Internet và hệ thống dây dẫn mạng LAN (mạng nội bộ), WAN (mạng diện rộng); bảo đảm hạn chế tối đa khả năng truy cập trái phép từ các nguồn không tin cậy.

h) Căn cứ theo điều kiện thực tế và yêu cầu bảo mật của từng đơn vị, đơn vị chủ quản hệ thống mạng nội bộ có trách nhiệm chủ động nghiên cứu, xây dựng và triển khai mô hình, giải pháp bảo đảm an toàn thông tin mạng phù hợp.

i) Thực hiện các biện pháp kỹ thuật cần thiết để bảo đảm an toàn thông tin trong quá trình kết nối Internet, bao gồm việc vô hiệu hóa hoặc ngắt kết nối các cổng mạng không sử dụng, đặc biệt tại các khu vực làm việc dùng chung của các đơn vị.

3. Bảo đảm ATTT đối với ứng dụng

a) Việc triển khai, vận hành và sử dụng các ứng dụng phải tuân thủ đầy đủ phương án bảo đảm ATTT đã được xây dựng theo tài liệu phân tích, thiết kế hệ thống.

b) Có phương án kiểm tra, thử nghiệm, đánh giá tính an toàn, bảo mật và khắc phục rủi ro trong quá trình triển khai, vận hành ứng dụng. Thực hiện đầy đủ việc cài đặt, cập nhật, vá lỗi bảo mật phần mềm, ứng dụng trên máy chủ, máy trạm và thiết bị kết nối mạng trong hệ thống nội bộ.

c) Ứng dụng phải thiết lập chính sách kiểm soát truy cập; có kết nối với hệ thống giám sát tập trung; có phương án bảo mật thông tin liên lạc, chống chối bỏ và bảo vệ mã nguồn.

d) Thực hiện phân quyền truy cập, quản trị và sử dụng ứng dụng, cơ sở dữ liệu theo chức năng, nhiệm vụ của người dùng; bảo đảm việc phân quyền theo từng cấp độ, phù hợp với yêu cầu nghiệp vụ của từng cá nhân hoặc nhóm người dùng.

đ) Ứng dụng phải có chức năng ghi, lưu trữ và quản lý nhật ký hệ thống, bao gồm: thông tin truy cập, thay đổi cấu hình, thời gian sử dụng, lỗi phát sinh và thông tin đăng nhập khi quản trị.

e) Thực hiện thu hồi tài khoản Office 365 đối với viên chức, người lao động khi nghỉ việc, chuyển công tác, chấm dứt hợp đồng lao động hoặc không còn sử dụng tài khoản; đối với sinh viên khi tốt nghiệp, thôi học hoặc bị buộc thôi học.

4. Bảo đảm an toàn thông tin đối với dữ liệu

a) Xây dựng phương án quản lý, lưu trữ dữ liệu quan trọng nhằm bảo đảm tính toàn vẹn, bảo mật và khả dụng. Thực hiện sao lưu định kỳ và có phương án khôi phục dữ liệu khi xảy ra sự cố.

b) Áp dụng biện pháp giám sát, cảnh báo để ngăn chặn truy cập, gửi/nhận dữ liệu trái phép. Khuyến khích sử dụng chữ ký số nhằm xác thực và bảo mật dữ liệu, đặc biệt trong các giao dịch yêu cầu chống chối bỏ nguồn gốc.

c) Xóa, tiêu hủy dữ liệu nhạy cảm không thể khôi phục khi thiết bị thay đổi mục đích sử dụng, bảo hành hoặc thanh lý. Nếu không thể xóa dữ liệu, phải tiêu hủy phần cứng lưu trữ.

d) Dữ liệu mật, tối mật, tuyệt mật phải được xử lý trên máy tính độc lập, không kết nối mạng; có mật khẩu, mã hóa và các biện pháp bảo mật khác.

đ) Sao lưu các tệp cấu hình, hệ điều hành máy chủ, cơ sở dữ liệu và dữ liệu nghiệp vụ; phân loại và lưu trữ theo nhóm; có giải pháp lưu trữ tại địa điểm khác phòng ngừa thiên tai, sự cố.

e) Xây dựng phương án bảo mật và kiểm soát việc chia sẻ, gửi/nhận thông tin trong và ngoài đơn vị.

g) Cá nhân có trách nhiệm bảo vệ thông tin của mình và tuân thủ quy định của pháp luật về cung cấp thông tin cá nhân khi sử dụng dịch vụ trên mạng, đồng thời có trách nhiệm bảo đảm ATTT đối với thông tin do mình xử lý theo Nghị định số 13/2023/NĐ-CP.

h) Tổ chức triển khai việc ký cam kết bằng văn bản về bảo đảm an toàn thông tin và bảo mật thông tin đối với viên chức, người lao động có trách nhiệm tiếp cận, quản lý thông tin, dữ liệu quan trọng hoặc tham gia quản trị các hệ thống thông tin trọng yếu của đơn vị.

5. Đảm bảo an toàn thông tin đối với thiết bị đầu cuối

a) Ban hành và thực hiện chính sách, quy trình quản lý thiết bị đầu cuối, bao gồm vận hành, kết nối, truy cập từ xa, cài đặt, cấu hình bảo mật và đánh giá, xử lý các điểm yếu an toàn trước khi đưa thiết bị vào sử dụng.

b) Quản lý và cập nhật thông tin thiết bị đầu cuối (tên, chủng loại, địa chỉ MAC, địa chỉ IP) và kiểm soát việc kết nối thiết bị vào hệ thống mạng theo địa chỉ MAC, IP.

c) Xây dựng quy trình bảo dưỡng, bảo trì và hướng dẫn sử dụng thiết bị đầu cuối; tổ chức kiểm tra, sửa chữa định kỳ đối với thiết bị hoạt động và thiết bị dự phòng.

d) Thực hiện sao lưu dữ liệu định kỳ để đảm bảo phục hồi thông tin khi thiết bị gặp sự cố hoặc bị tấn công.

đ) Triển khai hệ thống giám sát hoạt động thiết bị đầu cuối, phát hiện hành vi bất thường; đồng thời xây dựng quy trình ứng phó sự cố bảo mật để xử lý kịp thời các tình huống phát sinh.

6. Đảm bảo an toàn thông tin đối với cổng, trang thông tin điện tử

a) Quản lý toàn bộ phiên bản mã nguồn, tổ chức mô hình vận hành hợp lý, triển khai các hệ thống phòng vệ như tường lửa, hệ thống phát hiện và phòng ngừa xâm nhập (IDS/IPS), tường lửa ứng dụng web (WAF).

b) Áp dụng phương thức xác thực đa yếu tố (MFA) nhằm đảm bảo chỉ người dùng hợp lệ được truy cập hệ thống; đồng thời triển khai giám sát và phát hiện tấn công để kịp thời phát hiện các hành vi bất thường.

c) Xây dựng và thực hiện quy trình ứng phó sự cố bảo mật, kiểm tra đánh giá định kỳ để phát hiện và khắc phục lỗ hổng hệ thống.

d) Trước khi đưa vào sử dụng hoặc bổ sung chức năng mới, tiến hành đánh giá, kiểm định bảo mật; thành lập bộ phận chuyên trách kiểm tra, giám sát, phát hiện lỗi và lỗ hổng bảo mật để cảnh báo và xử lý kịp thời.

đ) Xây dựng phương án sao lưu và phục hồi toàn diện đối với cổng, trang thông tin điện tử, thực hiện sao lưu dữ liệu, mã nguồn và cơ sở dữ liệu ít nhất mỗi tháng một lần để bảo đảm khả năng khôi phục hệ thống trong vòng 24 giờ khi xảy ra sự cố.

7. Đảm bảo an toàn thông tin với thư điện tử

a) Viên chức, người lao động không sử dụng hộp thư điện tử công cộng trong công việc và không sử dụng thư điện tử công vụ cho mục đích cá nhân. Mỗi cá nhân có trách nhiệm đặt mật khẩu đủ mạnh cho hộp thư điện tử của mình.

b) Thực hiện sao lưu định kỳ các email quan trọng nhằm đảm bảo phục hồi dữ liệu khi xảy ra sự cố.

c) Trước khi mở tệp đính kèm hoặc nhấp vào liên kết, cần xác minh tính xác thực của người gửi, tuyệt đối không mở các tệp hoặc liên kết từ nguồn không rõ ràng hoặc nghi ngờ.

d) Cài đặt và duy trì phần mềm diệt virus để phát hiện, ngăn chặn phần mềm độc hại từ email; giám sát hoạt động để phát hiện các dấu hiệu bất thường hoặc xâm nhập.

đ) Đơn vị quản lý hệ thống thư điện tử xây dựng phương án đảm bảo an toàn, tính khả dụng truy cập và các biện pháp chống thư rác. Khi viên chức, người lao động nghỉ việc thì hộp thư điện tử sẽ bị khóa và xóa bỏ khỏi hệ thống thư điện tử.

8. Đảm bảo an toàn thông tin đối với loại hình thuê dịch vụ máy chủ ảo

a) Lựa chọn nhà cung cấp dịch vụ máy chủ ảo uy tín, có chính sách bảo mật rõ ràng và hỗ trợ kỹ thuật 24/7.

b) Hệ điều hành và phần mềm trên máy chủ ảo phải được cập nhật phiên bản mới liên tục; sử dụng tường lửa để kiểm soát lưu lượng mạng đến máy chủ.

c) Thực hiện sao lưu định kỳ dữ liệu và kiểm tra khả năng khôi phục từ bản sao lưu; mã hóa dữ liệu nhạy cảm khi truyền và lưu trữ.

d) Xây dựng kế hoạch ứng phó sự cố bảo mật và thực hiện kiểm tra đánh giá bảo mật định kỳ.

đ) Đảm bảo rằng tất cả các ứng dụng và dịch vụ trên máy chủ luôn được cập nhật và vá lỗi kịp thời, đồng thời thực hiện kiểm tra bảo mật thường xuyên để phát hiện và khắc phục các lỗ hổng có thể bị khai thác.

e) Ban hành và thực thi chính sách bảo mật trong quản lý, sử dụng máy chủ ảo.

g) Bảo vệ các công cụ quản lý máy chủ từ xa bằng cách sử dụng chứng thư số và hạn chế quyền truy cập qua SSH (Secure Shell) hoặc RDP (Remote Desktop Protocol) chỉ từ các địa chỉ IP tin cậy; cập nhật và bảo mật phần mềm quản lý đầu cuối để ngăn chặn các cuộc tấn công từ xa.

9. Đảm bảo an toàn thông tin đối với phần mềm độc hại

a) Áp dụng các chính sách, quy trình quản lý phần mềm độc hại bao gồm: cài đặt, cập nhật, sử dụng phần mềm phòng chống mã độc; dò quét, kiểm tra phần mềm độc hại trên máy tính, máy chủ, thiết bị di động và việc truy cập các trang thông tin trên mạng; gửi nhận tập tin qua môi trường mạng và các thiết bị lưu trữ di động.

b) Thực hiện sao lưu dữ liệu quan trọng định kỳ để đảm bảo có thể khôi phục dữ liệu nếu hệ thống bị tấn công bởi phần mềm độc hại.

c) Định kỳ thực hiện kiểm tra và dò quét phần mềm độc hại trên toàn bộ hệ thống, thực hiện kiểm tra và xử lý phần mềm độc hại khi phát hiện dấu hiệu hoặc cảnh báo về dấu hiệu phần mềm độc hại xuất hiện trên hệ thống.

d) Viên chức và người lao động phải được hướng dẫn về phòng chống mã độc, các rủi ro do mã độc gây ra; không được tự ý cài đặt hoặc gỡ bỏ các phần mềm trên máy trạm khi chưa có sự đồng ý của người có thẩm quyền theo quy định của đơn vị; khi phát hiện ra bất kỳ dấu hiệu nào liên quan đến việc bị nhiễm mã độc trên máy trạm người sử dụng phải báo trực tiếp cho bộ phận chuyên trách của đơn vị để xử lý.

Điều 10. Bảo đảm ATTT khi tiếp nhận, phát triển và bảo trì HTTT

1. Khi tiếp nhận, phát triển, nâng cấp, bảo trì HTTT, chủ quản HTTT phải rà soát cấp độ, phương án bảo đảm an toàn của HTTT và thực hiện điều chỉnh, bổ sung hoặc thay mới hồ sơ đề xuất cấp độ trong trường hợp cần thiết, đồng thời đơn vị phải tiến hành phân tích, xác định rủi ro có thể xảy ra, đánh giá phạm vi tác động và chuẩn bị các biện pháp hạn chế, loại trừ các rủi ro này và yêu cầu các bên cung cấp, thi công, các cá nhân liên quan thực hiện.

2. Trong quá trình vận hành HTTT, chủ quản HTTT cần thực hiện đánh giá, phân loại HTTT theo cấp độ; triển khai phương án bảo đảm an toàn HTTT đáp ứng yêu cầu

cơ bản trong tiêu chuẩn, quy chuẩn kỹ thuật về bảo đảm an toàn HTTT theo cấp độ; thường xuyên kiểm tra, giám sát an toàn HTTT; tuân thủ quy trình vận hành, quy trình xử lý sự cố đã xây dựng; ghi lại và lưu trữ đầy đủ thông tin nhật ký hệ thống để phục vụ quản lý, kiểm soát thông tin.

3. Các HTTT được cài đặt tại Trung tâm dữ liệu/Phòng máy chủ cần đáp ứng các yêu cầu: tách biệt với các môi trường phát triển, kiểm tra và thử nghiệm; không cài đặt các công cụ, phương tiện phát triển ứng dụng; loại bỏ hoặc tắt các tính năng, phần mềm tiện ích không sử dụng trên HTTT; áp dụng các biện pháp bảo đảm tính toàn vẹn dữ liệu và bảo đảm ATTT; mọi thao tác trên hệ thống phải được lưu vết, sẵn sàng cho kiểm tra, kiểm soát khi cần thiết.

4. Trong quá trình phát triển, bảo trì các ứng dụng cho các HTTT chủ quản HTTT có trách nhiệm yêu cầu các đối tác (nếu có) thực hiện các công tác đảm bảo an toàn thông tin, tránh lộ, lọt mã nguồn và dữ liệu, tài liệu thiết kế, quản trị hệ thống mà đối tác đang xử lý ra bên ngoài.

Điều 11. Kiểm tra, đánh giá ATTT

1. Chủ quản HTTT có thẩm quyền yêu cầu kiểm tra, đánh giá ATTT đối với các hệ thống thông tin thuộc phạm vi quản lý, thực hiện theo quy định tại Điều 11 và Điều 12 của Thông tư số 12/2022/TT-BTTTT.

2. Đơn vị vận hành HTTT chịu trách nhiệm đánh giá hiệu quả các biện pháp bảo đảm ATTT theo thẩm quyền; kết quả đánh giá làm cơ sở để điều chỉnh, hoàn thiện phương án bảo đảm ATTT cho phù hợp.

Điều 12. Quản lý rủi ro, lỗ hổng, điểm yếu ATTT

1. Đơn vị chuyên trách ATTT phối hợp với đơn vị vận hành HTTT của chủ quản HTTT tổ chức quản lý lỗ hổng, điểm yếu ATTT theo các nội dung sau:

- a) Lập danh sách toàn bộ thiết bị, ứng dụng đang sử dụng trong phạm vi quản lý.
- b) Thiết lập, duy trì kênh tiếp nhận thông tin về lỗ hổng, điểm yếu ATTT từ các cơ quan, tổ chức có chức năng cảnh báo về ATTT; các đơn vị cung cấp thiết bị, ứng dụng thuộc phạm vi điểm a khoản này.
- c) Quản lý, giám sát việc cài đặt bản vá lỗ hổng, điểm yếu ATTT. Sử dụng và cập nhật liên tục các công cụ dò quét lỗ hổng, điểm yếu ATTT để các công cụ này có thể phát hiện được các lỗ hổng bảo mật mới nhất.
- d) Triển khai cài đặt bản vá lỗ hổng, điểm yếu ATTT sau khi bản vá được phát hành; áp dụng các biện pháp bảo vệ tạm thời trong trường hợp bản vá bảo mật chưa được phát hành hoặc chưa đủ điều kiện để triển khai.

2. Đơn vị chuyên trách ATTT phối hợp với đơn vị vận hành HTTT triển khai quản lý rủi ro ATTT trên cơ sở quản lý lỗ hổng, điểm yếu ATTT theo quy định tại khoản 1 Điều này và theo hướng dẫn của cơ quan có thẩm quyền.

3. Định kỳ hằng năm kiểm tra, đánh giá điểm yếu ATTT cho toàn bộ HTTT; thực hiện quy trình kiểm tra, đánh giá, xử lý điểm yếu ATTT khi có thông tin hoặc nhận được cảnh báo về điểm yếu ATTT đối với thành phần cụ thể trong hệ thống.

4. Hoạt động đánh giá phát hiện mã độc, lỗ hổng, điểm yếu, thử nghiệm xâm nhập hệ thống thực hiện theo quy định tại điểm c khoản 2 Điều 20 của Nghị định số 85/2016/NĐ-CP và Điều 11 của Thông tư số 12/2022/TT-BTTTT.

Điều 13. Giám sát ATTT

1. Nguyên tắc, yêu cầu, nội dung, phương thức, hệ thống kỹ thuật phục vụ công tác giám sát thực hiện theo quy định tại Điều 3 đến Điều 9 của Thông tư số 31/2017/TT-BTTTT ngày 15/11/2017 của Bộ Thông tin và Truyền thông về quy định hoạt động giám sát an toàn hệ thống thông tin.

2. Các HTTT của các trường DHTV, các đơn vị trực thuộc ĐHĐN phải có chức năng ghi và lưu trữ nhật ký về hoạt động của hệ thống và người sử dụng HTTT; chức năng ghi nhật ký và thông tin nhật ký, chống giả mạo, sửa đổi, phá hủy và truy cập trái phép.

Điều 14. Ứng cứu sự cố ATTT

1. Khi có nguy cơ mất an toàn ANM hoặc sự cố xảy ra ở mức độ thấp thì đơn vị chuyên trách về ứng cứu sự cố ATTT của chủ quản HTTT phối hợp với đơn vị, cá nhân bị ảnh hưởng tự xử lý, khắc phục hoặc liên hệ với đơn vị cung cấp sản phẩm, dịch vụ viễn thông, internet, đơn vị triển khai ứng dụng để được tư vấn, hỗ trợ ngăn chặn, xử lý, khắc phục.

2. Khi có nguy cơ hoặc sự cố ATTT xảy ra ở mức độ xét thấy không có khả năng tự xử lý được thì đơn vị chuyên trách về ứng cứu sự cố ATTT báo cáo chủ quản HTTT để có phương án xử lý.

3. Đơn vị chuyên trách về ứng cứu sự cố ATTT thực hiện trách nhiệm quy định tại khoản 2 Điều 6 Quyết định số 05/2017/QĐ-TTg ngày 16/03/2017 của Thủ tướng Chính phủ quy định về hệ thống phương án ứng cứu khẩn cấp bảo đảm an toàn thông tin mạng quốc gia.

4. Quy trình ứng cứu sự cố ATTT được thực hiện theo Quyết định số 05/2017/QĐ-TTg và Thông tư số 20/2017/TT-BTTTT ngày 12/9/2017 của Bộ Thông tin và Truyền thông quy định về điều phối, ứng cứu sự cố an toàn thông tin mạng trên toàn quốc.

Điều 15. Kết thúc vận hành, khai thác, thanh lý, hủy bỏ HTTT

1. Khi kết thúc vận hành, khai thác, thanh lý, hủy bỏ HTTT đơn vị chủ quản HTTT thực hiện hủy bỏ toàn bộ thông tin, dữ liệu trên hệ thống.

2. Đối với các HTTT có dữ liệu được lưu trữ trên tài sản vật lý cần phải mang đi bảo hành, bảo dưỡng, sửa chữa bên ngoài thì phải được sự phê duyệt của chủ quản HTTT và thực hiện các biện pháp bảo vệ dữ liệu; có cam kết bảo mật thông tin giữa bên có dữ liệu và bên cung cấp dịch vụ sửa chữa thiết bị lưu trữ dữ liệu.

Chương III

BẢO ĐẢM AN NINH MẠNG

Điều 16. Triển khai hoạt động đảm bảo ANM

1. Các trường ĐHTV, các đơn vị trực thuộc ĐHĐN có trách nhiệm xây dựng quy định sử dụng, quản lý và bảo đảm ANM máy tính nội bộ, mạng máy tính có kết nối mạng internet do đơn vị mình quản lý.

2. Nội dung quy định sử dụng, bảo đảm ANM máy tính gồm những nội dung sau:

a) Xác định rõ hệ thống mạng thông tin và thông tin quan trọng cần ưu tiên bảo đảm ANM.

b) Quy định rõ các điều cấm và các nguyên tắc quản lý, sử dụng và bảo đảm ANM, mạng máy tính nội bộ có lưu trữ, truyền đưa bí mật nhà nước phải được tách biệt vật lý hoàn toàn với mạng máy tính, các thiết bị, phương tiện điện tử có kết nối mạng internet, trường hợp khác phải tuân thủ quy định của pháp luật về bảo vệ bí mật nhà nước.

c) Quy trình quản lý, nghiệp vụ, kỹ thuật trong vận hành, sử dụng và bảo đảm ANM đối với dữ liệu, hạ tầng kỹ thuật, trong đó phải đáp ứng các yêu cầu cơ bản bảo đảm an toàn HTTT.

d) Điều kiện về nhân sự làm công tác quản trị mạng, vận hành hệ thống, bảo đảm ANM, an toàn thông tin và liên quan đến hoạt động soạn thảo, lưu trữ, truyền đưa bí mật nhà nước qua hệ thống mạng máy tính.

đ) Quy định rõ trách nhiệm của từng bộ phận, viên chức, người lao động trong quản lý, sử dụng, bảo đảm ANM, an toàn thông tin.

e) Chế tài xử lý những vi phạm quy định về đảm bảo ANM.

3. Chủ quản HTTT ứng dụng, triển khai phương án, biện pháp, công nghệ bảo vệ ANM đối với hệ thống thông tin và thông tin, tài liệu được lưu trữ, soạn thảo, truyền đưa trên hệ thống thông tin thuộc phạm vi quản lý; khuyến khích các đơn vị sử dụng VLAN (Virtual Local Area Network) để quản trị mạng nhằm nâng cao tính an toàn dữ liệu, hạn chế bị tấn công mạng và dễ dàng tìm ra nguyên nhân khắc phục hệ thống khi bị sự cố.

4. Chủ quản HTTT tổ chức bồi dưỡng kiến thức về ANM cho viên chức, người lao động; nâng cao năng lực bảo vệ ANM cho lực lượng bảo vệ ANM.

5. Chủ quản HTTT triển khai kiểm tra ANM đối với hệ thống thông tin; phòng, chống hành vi vi phạm pháp luật về ANM; ứng phó, khắc phục sự cố ANM.

Điều 17. Phương án bảo đảm ANM đối với HTTT

1. Chủ quản HTTT có trách nhiệm ban hành phương án bảo đảm ANM đối với HTTT do mình quản lý, bảo đảm đồng bộ, thống nhất, tập trung, có sự chia sẻ tài nguyên để tối ưu hiệu năng, tránh đầu tư trùng lặp.

2. Phương án bảo đảm ANM đối với HTTT bao gồm:

a) Quy định bảo đảm ANM trong thiết kế, xây dựng HTTT, đáp ứng yêu cầu cơ bản như yêu cầu quản lý, kỹ thuật, nghiệp vụ.

- b) Thẩm định ANM.
- c) Kiểm tra, đánh giá ANM.
- d) Giám sát ANM.
- đ) Dự phòng, ứng phó, khắc phục sự cố, tình huống nguy hiểm về ANM.
- e) Quản lý rủi ro.
- g) Kết thúc vận hành, khai thác, sửa chữa, thanh lý, hủy bỏ.

Điều 18. Phương án ứng phó, khắc phục sự cố ANM

1. Chủ quản HTTT có trách nhiệm xây dựng phương án ứng phó, khắc phục sự cố ANM đáp ứng theo yêu cầu quy định tại khoản 1 Điều 25 Nghị định 53/2022/NĐ-CP ngày 15/8/2022 của Chính phủ quy định chi tiết một số điều Luật An ninh mạng.

2. Nội dung phương án ứng phó, khắc phục sự cố ANM gồm:

- a) Các quy định chung.
- b) Đánh giá các nguy cơ, sự cố ANM.
- c) Phương án ứng phó, khắc phục đối với một số tình huống cụ thể.
- d) Nhiệm vụ, trách nhiệm của các cơ quan trong tổ chức, điều phối, xử lý, ứng phó, khắc phục sự cố.
- đ) Huấn luyện, diễn tập, phòng ngừa sự cố, giám sát phát hiện, bảo đảm các điều kiện sẵn sàng đối phó, khắc phục sự cố.
- e) Các giải pháp đảm bảo, tổ chức triển khai phương án, kế hoạch và kinh phí thực hiện.

Điều 19. Lực lượng bảo vệ ANM

- 1. Trung tâm IDC là đơn vị bảo vệ ANM cho các HTTT do ĐHĐN làm chủ quản HTTT và các HTTT được giao khác.
- 2. Các trường ĐHTV, các đơn vị trực thuộc ĐHĐN chịu trách nhiệm bố trí lực lượng bảo vệ ANM tại đơn vị mình.
- 3. Tổ chức, cá nhân được huy động tham gia bảo vệ ANM.

Chương IV

TRÁCH NHIỆM CỦA CÁC TỔ CHỨC LIÊN QUAN

Điều 20. Trách nhiệm của Trung tâm IDC

- 1. Chủ trì, làm đầu mối hướng dẫn, theo dõi, giám sát, đôn đốc, kiểm tra việc triển khai, tổ chức thực hiện Quy chế này.
- 2. Tham mưu triển khai thực hiện các nhiệm vụ, trách nhiệm của chủ quản HTTT đối với các HTTT do ĐHĐN là chủ quản HTTT và thực hiện các nhiệm vụ được giao tại Quy chế này.
- 3. Tham mưu xây dựng quy định sử dụng, quản lý và bảo đảm ANM máy tính nội bộ, mạng máy tính có kết nối mạng internet do đơn vị mình quản lý.

4. Tham mưu tổ chức thường xuyên các hoạt động tuyên truyền, phổ biến nâng cao nhận thức về bảo đảm an toàn thông tin mạng và ANM đến toàn thể viên chức và người lao động tại Cơ quan ĐHĐN.

5. Tiếp nhận và đưa ra các cảnh báo về an toàn, an ninh thông tin, áp dụng các biện pháp để khắc phục và hạn chế tối đa thiệt hại do sự cố mất ATTT, ANM tại ĐHĐN.

6. Nhắc nhở, tạm dừng cung cấp các dịch vụ mạng ĐHĐN đối với đơn vị, người sử dụng có liên quan để kiểm tra, khắc phục sự cố. Trường hợp có sự cố nghiêm trọng vượt quá khả năng khắc phục phải báo cáo Lãnh đạo ĐHĐN và thông báo cho các tổ chức hỗ trợ xử lý sự cố mất ATTT, ANM để cùng phối hợp giải quyết.

7. Lập kế hoạch hàng năm trình Lãnh đạo ĐHĐN phê duyệt và tổ chức triển khai kế hoạch bảo đảm ATTT, ANM của ĐHĐN và kế hoạch đào tạo, bồi dưỡng nghiệp vụ cho viên chức chuyên trách ATTT, ANM.

8. Hàng năm, phối hợp với các đơn vị liên quan tham mưu kiểm tra về công tác bảo đảm ATTT, ANM đối với các trường ĐHTV, các đơn vị thuộc, trực thuộc ĐHĐN.

9. Cấp mới, sửa đổi, thu hồi tài khoản và cấp quyền khai thác tài nguyên mạng ĐHĐN cho người sử dụng đúng chức năng, nhiệm vụ khi có yêu cầu bằng văn bản.

10. Phối hợp chặt chẽ với các cấp có thẩm quyền và các cơ quan liên quan trong công tác phòng ngừa, đấu tranh, ngăn chặn các hoạt động xâm phạm ATTT, ANM.

11. Hàng năm rà soát lại quy chế bảo đảm ATTT, ANM để kiểm tra lại tính phù hợp và tham mưu thực hiện, cập nhật, bổ sung.

12. Theo dõi, tổng hợp và báo cáo định kỳ theo quy định.

Điều 21. Trách nhiệm của các trường ĐHTV, các đơn vị trực thuộc ĐHĐN

1. Chịu trách nhiệm trước Giám đốc ĐHĐN trong việc bảo đảm ATTT, ANM của đơn vị mình.

2. Thực hiện các nhiệm vụ được giao tại Quy chế này.

3. Xây dựng kế hoạch bảo vệ, quản lý và thực hiện bảo dưỡng định kỳ các trang thiết bị đầu cuối lắp đặt tại đơn vị.

4. Xây dựng, triển khai Quy chế/quy định bảo đảm ATTT, ANM tại đơn vị bảo đảm phù hợp với Quy chế này và các yêu cầu cụ thể của đơn vị.

5. Thường xuyên tổ chức các hoạt động tuyên truyền, phổ biến nâng cao nhận thức về bảo đảm ATTT và ANM đến toàn thể bộ viên chức và người lao động tại đơn vị.

6. Xây dựng kế hoạch tổ chức đào tạo, bồi dưỡng nghiệp vụ về ATTT, ANM cho viên chức CNTT, viên chức chuyên trách ATTT, ANM; đào tạo cơ bản về an toàn thông tin cho đội ngũ viên chức quản lý, người sử dụng máy tính thuộc đơn vị.

7. Trường hợp phát hiện mất an toàn, an ninh thông tin không có khả năng xử lý phải thông báo kịp thời tới Trung tâm IDC bằng văn bản và các hình thức liên lạc khác để phối hợp giải quyết.

Điều 22. Trách nhiệm cá nhân

1. Chấp hành nghiêm túc các quy định về ATTT, ANM tại quy định này và các quy định khác của pháp luật về an toàn thông tin; nâng cao ý thức cảnh giác và trách

nhiệm bảo đảm an toàn thông tin trong phạm vi trách nhiệm và quyền hạn được giao; chịu trách nhiệm trước pháp luật và lãnh đạo đơn vị về các vi phạm, thất thoát dữ liệu quan trọng hoặc dữ liệu mật do không tuân thủ quy định và các văn bản khác của pháp luật về ATTT, ANM.

2. Tự quản lý, bảo quản thiết bị mà mình được giao sử dụng. Khi phát hiện sự cố phải báo ngay với cấp trên và bộ phận chuyên trách về công nghệ thông tin để kịp thời ngăn chặn, xử lý.

3. Tích cực tham gia các chương trình đào tạo, hội nghị về an toàn thông tin do các đơn vị chuyên môn tổ chức, nhằm nâng cao nhận thức về trách nhiệm đảm bảo ATTT, ANM.

Chương V

TỔ CHỨC THỰC HIỆN

Điều 23. Kinh phí thực hiện

1. Kinh phí đảm bảo ATTT, ANM thực hiện lồng ghép, tích hợp với các chương trình, đề án, nhiệm vụ công nghệ thông tin từ nguồn ngân sách nhà nước và các nguồn kinh phí hợp pháp khác của các đơn vị.

2. Căn cứ vào kế hoạch hàng năm, các đơn vị liên quan có trách nhiệm xây dựng kế hoạch, đề xuất dự toán kinh phí cho các hoạt động đảm bảo ATTT, ANM trình các cấp có thẩm quyền phê duyệt.

Điều 24. Kiểm tra, đánh giá công tác đảm bảo ATTT, ANM

Chủ quản HTTT thường xuyên kiểm tra, theo dõi và đánh giá công tác bảo đảm ATTT, ANM tại đơn vị mình, coi đây là nhiệm vụ trọng tâm của đơn vị.

Điều 25. Chế độ báo cáo

1. Phương thức gửi, nhận báo cáo: gửi qua hệ thống quản lý văn bản và điều hành; gửi qua hệ thống thư điện tử; các phương thức khác theo quy định của pháp luật.

2. Tần suất thực hiện báo cáo:

a) Định kỳ hàng năm.

b) Đột xuất theo đề nghị của cơ quan có thẩm quyền.

3. Nội dung báo cáo

a) Báo cáo định kỳ hàng năm về đảm bảo an toàn HTTT theo cấp độ quy định tại Điều 14 Thông tư 12/2022/TT-BTTTT, thời hạn hoàn thành trước ngày 20 tháng 12 hằng năm.

b) Báo cáo định kỳ hàng năm về hoạt động giám sát của chủ quản HTTT theo Mẫu số 01 tại Phụ lục 2 Thông tư 02/2023/TT-BTTTT ngày 21/3/2023 của Bộ Thông tin và Truyền thông quy định chế độ báo cáo định kỳ thuộc phạm vi quản lý nhà nước của Bộ Thông tin và Truyền thông, thời hạn hoàn thành trước ngày 24 tháng 11 hằng năm.

4. Trách nhiệm thực hiện báo cáo

a) Các trường ĐHTV và các đơn vị trực thuộc ĐHĐN có trách nhiệm xây dựng và gửi đầy đủ báo cáo định kỳ, báo cáo đột xuất (khi có yêu cầu) theo quy định tại khoản 3 Điều này về ĐHĐN thông qua Trung tâm IDC.

b) Trung tâm IDC có trách nhiệm tiếp nhận và tổng hợp các báo cáo do các trường ĐHTV, các đơn vị trực thuộc ĐHĐN gửi về; xây dựng báo cáo tổng hợp, trình lãnh đạo ĐHĐN xem xét, ký ban hành và gửi báo cáo đến các cơ quan quản lý nhà nước có thẩm quyền về ATTT, ANM theo quy định.

Điều 26. Khen thưởng, kỷ luật

1. Kết quả thực hiện Quy chế này là một trong những tiêu chí chấm điểm thi đua trong lĩnh vực liên quan đến công tác tăng cường ứng dụng CNTT và CDS.

2. Đơn vị, cá nhân vi phạm Quy chế này và các quy định khác của pháp luật về bảo đảm ATTT, ANM; tùy theo tính chất, mức độ vi phạm sẽ xem xét xử lý theo quy định.

Điều 27. Điều khoản thi hành

1. Trung tâm IDC, các trường ĐHTV, các đơn vị thuộc và trực thuộc ĐHĐN có trách nhiệm hướng dẫn, triển khai và kiểm tra việc thực hiện Quy chế này.

2. Trong quá trình tổ chức thực hiện, nếu có khó khăn, vướng mắc cần điều chỉnh, sửa đổi, bổ sung; các đơn vị phản ánh kịp thời về Trung tâm IDC để tổng hợp, báo cáo Giám đốc ĐHĐN xem xét, điều chỉnh cho phù hợp. / 



Phụ lục I

HƯỚNG DẪN XÁC ĐỊNH CẤP ĐỘ HTTT

(Kèm theo Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng của ĐHĐN được ban hành kèm theo Quyết định số 245/2025 ngày 26/6/2025 của Giám đốc ĐHĐN)

Cấp độ của một HTTT được xác định dựa trên hai yếu tố chính: (1) loại thông tin mà HTTT xử lý và (2) loại hình HTTT. Tiêu chí xác định cấp độ của một HTTT là tập hợp các điều kiện kết hợp giữa hai yếu tố này. Việc xác định cụ thể (1) và (2) được thực hiện như hướng dẫn sau đây:

1. Xác định loại thông tin HTTT xử lý

Một HTTT có thể xử lý các loại thông tin sau: (i) thông tin công cộng; (ii) thông tin riêng; (iii) thông tin cá nhân; và (iv) thông tin bí mật nhà nước (chi tiết xem tại khoản 1, Điều 6 Nghị định 85/NĐ-CP). Các loại thông tin này được phân loại theo mức độ bí mật tăng dần, theo thứ tự: thông tin công cộng; thông tin riêng, thông tin cá nhân; thông tin bí mật nhà nước. Khi xác định cấp độ an toàn của HTTT căn cứ theo loại thông tin mà hệ thống xử lý được thực hiện theo nguyên tắc: loại thông tin có mức độ bí mật cao nhất trong HTTT sẽ quyết định cấp độ của HTTT đó. Ví dụ: nếu HTTT xử lý thông tin riêng hoặc thông tin cá nhân thì cấp độ HTTT tối thiểu phải xác định là cấp độ 2.

2. Xác định loại hình HTTT

HTTT được phân loại theo chức năng phục vụ hoạt động nghiệp vụ, bao gồm 04 loại như sau:

- HTTT phục vụ hoạt động nội bộ là hệ thống chỉ phục vụ hoạt động quản trị, vận hành nội bộ của cơ quan, tổ chức.

- HTTT phục vụ người dân, doanh nghiệp là hệ thống trực tiếp hoặc hỗ trợ cung cấp dịch vụ công trực tuyến, bao gồm dịch vụ trực tuyến khác và dịch vụ công trực tuyến khác trong các lĩnh vực viễn thông, công nghệ thông tin, thương mại, tài chính, ngân hàng, y tế, giáo dục và các lĩnh vực chuyên ngành khác.

- Hệ thống cơ sở hạ tầng thông tin là tập hợp trang thiết bị, đường truyền kết nối phục vụ hoạt động chung của nhiều cơ quan, tổ chức như mạng diện rộng, cơ sở dữ liệu, trung tâm dữ liệu, điện toán đám mây; xác thực điện tử, chứng thực điện tử, chữ ký số; kết nối liên thông các HTTT.

- HTTT điều khiển công nghiệp là hệ thống có chức năng giám sát, thu thập dữ liệu, quản lý và kiểm soát các hạng mục quan trọng phục vụ điều khiển và vận hành bình thường các công trình xây dựng.

Hệ thống thông tin khác là hệ thống thông tin không thuộc 04 loại hình đã nêu trên, được sử dụng để trực tiếp phục vụ hoặc hỗ trợ hoạt động nghiệp vụ, sản xuất, kinh doanh cụ thể của cơ quan, tổ chức theo lĩnh vực chuyên ngành.

3. Xác định cấp độ HTTT

Tiêu chí xác định cấp độ HTTT được quy định tại Điều 7 đến Điều 11 của Nghị định 85/2016/NĐ-CP. Việc xác định cấp độ hệ thống thông tin được thực hiện theo các trường hợp sau:

- Trường hợp xác định cấp độ HTTT dựa trên loại thông tin mà HTTT đó xử lý:

- HTTT chỉ xử lý thông tin công cộng thuộc cấp độ 1.
- HTTT xử lý thông tin riêng hoặc thông tin cá nhân có cấp độ tối thiểu là cấp độ 2.
- Hệ thống xử lý thông tin bí mật nhà nước có cấp độ tối thiểu là cấp độ 3.
- Trường hợp HTTT cung cấp thông tin và dịch vụ công trực tuyến:
 - HTTT cung cấp thông tin và dịch vụ công trực tuyến từ mức 2 trở xuống thì cấp độ đề xuất cho HTTT là cấp độ 2.
 - HTTT cung cấp thông tin và dịch vụ công trực tuyến từ mức 3 trở lên thì cấp độ đề xuất cho HTTT là cấp độ 3.
- Trường hợp HTTT cung cấp dịch vụ trực tuyến khác:
 - HTTT xử lý thông tin riêng, thông tin cá nhân dưới 10.000 người sử dụng, cấp độ đề xuất cho HTTT là cấp độ 2.
 - HTTT xử lý thông tin riêng, thông tin cá nhân trên 10.000 người sử dụng, cấp độ đề xuất cho HTTT là cấp độ 3.

Đối với các trường hợp khác, việc xác định cấp độ an toàn thông tin căn cứ theo quy định tại Nghị định 85/2016/NĐ-CP và Thông tư số 12/2022/TT-BTTTT.

Phụ lục II

HƯỚNG DẪN XÂY DỰNG HỒ SƠ ĐỀ XUẤT CẤP ĐỘ HTTT

(Kèm theo Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng của ĐHĐN được ban hành kèm theo Quyết định số 2453 ngày 26/6/2025 của Giám đốc ĐHĐN)

Hồ sơ đề xuất cấp độ (HSDXCĐ) HTTT bao gồm: (1) tài liệu mô tả, thuyết minh tổng quan về hệ thống thông tin; (2) tài liệu thiết kế HTTT; (3) tài liệu thuyết minh về việc đề xuất cấp độ căn cứ trên các tiêu chí theo quy định của pháp luật; (4) tài liệu thuyết minh phương án bảo đảm an toàn thông tin theo cấp độ tương ứng.

Khi xây dựng HSDXCĐ, đối với HTTT lớn gồm nhiều hệ thống thành phần, nếu các hệ thống thành phần được quản lý và chia sẻ trên cùng một hạ tầng dùng chung, thuộc cùng đơn vị vận hành và có thể triển khai phương án bảo đảm an toàn thông tin chung cho toàn bộ hạ tầng, thì có thể lập một HSDXCĐ chung cho toàn bộ các hệ thống thành phần. Trường hợp hệ thống thành phần độc lập về hạ tầng, cơ chế quản lý và đơn vị vận hành thì phải xây dựng HSDXCĐ riêng cho từng hệ thống. Việc xây dựng HSDXCĐ được thực hiện theo hướng dẫn sau:

I. Thuyết minh tổng quan về HTTT

1. Thông tin Chủ quản HTTT

- Tên đơn vị:
- Số Quyết định thành lập.
- Quy định chức năng, nhiệm vụ và quyền hạn.
- Người đại diện: Họ và tên, Chức vụ.
- Địa chỉ: Địa chỉ trụ sở của đơn vị.
- Thông tin liên hệ: Số điện thoại, email

2. Thông tin Đơn vị vận hành HTTT

- Tên đơn vị vận hành HTTT:.....
- Số Quyết định thành lập.
- Quy định chức năng, nhiệm vụ và quyền hạn.
- Người đại diện: Họ và tên, Chức vụ.
- Địa chỉ: Địa chỉ trụ sở của đơn vị.
- Thông tin liên hệ: Số điện thoại, email.

3. Mô tả phạm vi, quy mô của hệ thống

- Phạm vi, quy mô của HTTT: Mô tả phạm vi, quy mô của HTTT.
- Đối tượng phục vụ của HTTT: Mô tả đối tượng phục vụ của HTTT.
- Danh mục các hệ thống thông tin thành phần/các dịch vụ được cung cấp bởi HTTT: Liệt kê danh mục các HTTT.

4. Mô tả cấu trúc của hệ thống

Mô tả cấu trúc hiện tại của Hệ thống, bao gồm các thông tin sau:

a) Mô hình logic tổng thể: mô tả thiết kế các vùng mạng chức năng có trong hệ thống; hướng kết nối mạng; các thiết bị đầu cuối; các thiết bị mạng.

b) Mô hình kết nối vật lý: Mô tả các thiết bị mạng, các thiết bị đầu cuối có trong hệ thống và các kết nối vật lý giữa các thiết bị.

c) Danh mục thiết bị sử dụng trong hệ thống: Cung cấp thông tin về các thiết bị mạng và các thiết bị đầu cuối có trong hệ thống, như bảng sau:

Bảng 1. Danh mục thiết bị sử dụng trong hệ thống

STT	Tên thiết bị/ Chủng loại	Vị trí triển khai	Mục đích sử dụng
1	FW01/ Chủng loại	Vùng core	Quản lý truy cập vào/ra và bảo vệ các vùng mạng.
...			

d) Danh mục các ứng dụng/dịch vụ cung cấp bởi hệ thống: Cung cấp thông tin các ứng dụng/dịch vụ có trên hệ thống bao gồm: tên dịch vụ; máy chủ triển khai/vị trí triển khai/hệ điều hành máy chủ; mục đích sử dụng dịch vụ, như bảng sau:

Bảng 2. Danh mục các ứng dụng/dịch vụ cung cấp bởi hệ thống

STT	Tên dịch vụ	Máy chủ/Ứng dụng cài đặt/Vùng mạng/HĐH	Mục đích sử dụng
1	Cổng thông tin nội bộ	Server01/Cài đặt Web-App /Vùng máy chủ nội bộ/HĐH Centos7	Cung cấp thông tin công khai cho người sử dụng nội bộ.
2			

e) Quy hoạch địa chỉ IP các vùng mạng trong hệ thống: Cung cấp thông tin gồm: vùng mạng; IP Private ; IP Public, như bảng sau:

Bảng 3. Quy hoạch địa chỉ IP các vùng mạng trong hệ thống

STT	Vùng mạng	IP Private	IP Public
1	DMZ	192.168.1.0/24	202.191.x.0/24
2			

II. Thuyết minh cấp độ đề xuất

1. Danh mục HTTT và cấp độ đề xuất

HTTT của đơn vị vận hành bao gồm các hệ thống thành phần với cấp độ đề xuất tương ứng, bao gồm:

TT	Hệ thống	Cấp độ đề xuất	Căn cứ đề xuất
1	Hệ thống cổng thông tin nội bộ	1	Điều 7 của Nghị định 85/2016/NĐ-CP
2	Hệ thống quản lý văn bản và điều hành	2	Điều 8 của Nghị định 85/2016/NĐ-CP
4	...	...	...

Lưu ý: khi xác định cấp độ, không cần thiết liệt kê ra hết các tiêu chí, mà chỉ đưa ra duy nhất một tiêu chí và tiêu chí đó đủ để xác định cấp độ cao nhất của HTTT.

2. Thuyết minh đề xuất cấp độ đối với HTTT

Thuyết minh chi tiết đối với các HTTT, trong đó cần làm rõ loại thông tin được xử lý, loại hệ thống thông tin, căn cứ đề xuất cấp độ đối với từng HTTT, ví dụ như sau:

- **Hệ thống cổng thông tin nội bộ:** Hệ thống cổng thông tin nội bộ chỉ xử lý thông tin công khai và phục vụ hoạt động nội bộ cho viên chức, người lao động của đơn vị. Căn cứ theo quy định tại Điều 7 của Nghị định 85/2016/NĐ-CP, HTTT này được đề xuất cấp độ 1.

- **Hệ thống quản lý văn bản và điều hành:** Hệ thống quản lý văn bản và điều hành có xử lý thông tin riêng của đơn vị và phục vụ hoạt động nội bộ cho viên chức, người lao động của đơn vị. Căn cứ theo quy định tại khoản 1 Điều 8 của Nghị định 85/2016/NĐ-CP, HTTT này được đề xuất cấp độ 2.

III. Thuyết minh phương án bảo đảm an toàn thông tin

- Đối với các yêu cầu an toàn về quản lý: Trường hợp các yêu cầu an toàn về quản lý đã được đáp ứng, thuyết minh phương án cần chỉ rõ các quy định tương ứng theo quy chế, chính sách bảo đảm an toàn thông tin đã ban hành. Trường hợp các yêu cầu chưa được đáp ứng đầy đủ, thuyết minh cần nêu rõ kế hoạch hoàn thiện quy chế, chính sách nhằm bảo đảm đáp ứng đầy đủ các yêu cầu an toàn thông tin theo quy định.

- Đối với các yêu cầu an toàn kỹ thuật: Trường hợp các yêu cầu kỹ thuật đã được đáp ứng, thuyết minh phương án cần mô tả cụ thể phương án triển khai, hiện trạng cấu hình và thiết lập hệ thống nhằm chứng minh sự phù hợp với các yêu cầu kỹ thuật được đề ra. Trường hợp chưa đáp ứng, cần trình bày rõ phương án, lộ trình nâng cấp hoặc điều chỉnh hệ thống nhằm đáp ứng đầy đủ các yêu cầu kỹ thuật đặt ra.

- Để thuyết minh chi tiết việc đáp ứng các yêu cầu an toàn quy định tại Thông tư số 12/2022/TT-BTTTT, đơn vị có thể tham khảo các yêu cầu an toàn cụ thể tại Tiêu chuẩn quốc gia TCVN 11930:2017 về yêu cầu cơ bản về an toàn hệ thống thông tin theo cấp độ.

1. Thuyết minh phương án bảo đảm an toàn thông tin về quản lý:

Thuyết minh phương án bảo đảm an toàn thông tin về quản lý bao gồm các nội dung và theo cấu trúc sau:

1.1. Thiết lập chính sách an toàn thông tin

a) Chính sách an toàn thông tin: Mô tả mục tiêu, nguyên tắc bảo đảm an toàn thông tin của đơn vị.

b) Xây dựng và công bố: Chính sách được đơn vị/bộ phận được ủy quyền thông qua trước khi công bố áp dụng.

c) Rà soát, sửa đổi: Định kỳ hoặc khi có thay đổi chính sách an toàn thông tin kiểm tra lại tính phù hợp và thực hiện rà soát, cập nhật, bổ sung.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Chính sách an toàn thông tin	5.1.1.1	6.1.1.1	7.1.1.1
2	Xây dựng và công bố	5.1.1.2	6.1.1.2	7.1.1.2
3	Rà soát, sửa đổi	5.1.1.3	6.1.1.3	7.1.1.3

1.2. Tổ chức bảo đảm an toàn thông tin

Cung cấp thông tin về cơ cấu, tổ chức bảo đảm an toàn thông tin của tổ chức, bao gồm: đơn vị chuyên trách về an toàn thông tin; đầu mối phối hợp với cơ quan/tổ chức có thẩm quyền trong hoạt động bảo đảm an toàn thông tin.

a) Đơn vị chuyên trách về an toàn thông tin: Thành lập hoặc chỉ định đơn vị/bộ phận chuyên trách về an toàn thông tin trong tổ chức.

b) Phối hợp với cơ quan/tổ chức có thẩm quyền: Có đầu mối liên hệ, phối hợp với các cơ quan, tổ chức có thẩm quyền quản lý về an toàn thông tin.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Đơn vị chuyên trách về an toàn thông tin	5.1.2.1	6.1.2.1	7.1.2.1
2	Phối hợp với cơ quan/tổ chức có thẩm quyền	5.1.2.2	6.1.2.2	7.1.2.2

1.3. Bảo đảm nguồn nhân lực

Đưa ra chính sách/quy trình thực hiện quản lý bảo đảm nguồn nhân lực an toàn thông tin của tổ chức, bao gồm: Tuyển dụng viên chức; quy chế/quy định bảo đảm an toàn thông tin trong quá trình làm việc và chấm dứt hoặc thay đổi công việc.

a) Tuyển dụng: Viên chức, người lao động được tuyển dụng vào vị trí làm về an toàn thông tin có trình độ, chuyên ngành về lĩnh vực công nghệ thông tin, an toàn thông tin, phù hợp với vị trí tuyển dụng.

b) Trong quá trình làm việc: Có quy định về việc thực hiện nội quy, quy chế bảo đảm an toàn thông tin cho người sử dụng, viên chức quản lý và vận hành hệ thống.

c) Chấm dứt hoặc thay đổi công việc: Viên chức, người lao động chấm dứt hoặc thay đổi công việc phải thu hồi thẻ truy cập, thông tin được lưu trên các phương tiện lưu trữ, các trang thiết bị máy móc, phần cứng, phần mềm và các tài sản khác (nếu có) thuộc sở hữu của đơn vị.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Tuyển dụng	5.1.3.1	6.1.3.1	7.1.3.1
2	Trong quá trình làm việc	5.1.3.2	6.1.3.2	7.1.3.2
3	Chấm dứt hoặc thay đổi công việc	5.1.3.3	6.1.3.3	7.1.3.3

1.4. Quản lý thiết kế, xây dựng hệ thống

Đưa ra chính sách/quy trình thực hiện quản lý thiết kế, xây dựng hệ thống của tổ chức, bao gồm:

a) Thiết kế an toàn hệ thống thông tin: Có tài liệu mô tả quy mô, phạm vi và đối tượng sử dụng, khai thác, quản lý vận hành hệ thống thông tin.

b) Phát triển phần mềm thuê khoán: Có biên bản, hợp đồng và các cam kết đối với bên thuê khoán các nội dung liên quan đến việc phát triển phần mềm thuê khoán.

c) Thử nghiệm và nghiệm thu hệ thống: Thực hiện kiểm thử hệ thống trước khi đưa vào vận hành, khai thác sử dụng.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Thiết kế an toàn hệ thống thông tin	5.1.4.1	6.1.4.1	7.1.4.1
2	Phát triển phần mềm thuê khoán	Không yêu cầu	6.1.4.2	7.1.4.2
3	Thử nghiệm và nghiệm thu hệ thống	5.1.4.2	6.1.4.3	7.1.4.3

1.5. Quản lý vận hành hệ thống

a) Quản lý an toàn mạng: Đưa ra chính sách/quy trình thực hiện quản lý an toàn hạ tầng mạng của đơn vị.

b) Quản lý an toàn máy chủ và ứng dụng: Đưa ra chính sách/quy trình thực hiện quản lý an toàn máy chủ và ứng dụng của đơn vị.

c) Quản lý an toàn dữ liệu: Đưa ra chính sách/quy trình thực hiện quản lý an toàn dữ liệu của đơn vị.

d) Quản lý an toàn thiết bị đầu cuối: Đưa ra chính sách/quy trình thực hiện quản lý an toàn thiết bị đầu cuối của đơn vị.

đ) Quản lý phòng chống phần mềm độc hại: Đưa ra chính sách/quy trình thực hiện quản lý phòng chống phần mềm độc hại của đơn vị.

e) Quản lý giám sát an toàn hệ thống thông tin: Đưa ra chính sách/quy trình thực hiện quản lý phòng chống phần mềm độc hại của đơn vị.

g) Quản lý điểm yếu an toàn thông tin: Đưa ra chính sách/quy trình thực hiện quản lý điểm yếu an toàn thông tin của đơn vị.

h) Quản lý sự cố an toàn thông tin: Đưa ra chính sách/quy trình thực hiện quản lý sự cố an toàn thông tin của đơn vị.

i) Quản lý an toàn người sử dụng đầu cuối: Đưa ra chính sách/quy trình thực hiện quản lý an toàn người sử dụng đầu cuối đơn vị.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Quản lý an toàn mạng	5.1.5.1	6.1.5.1	7.1.5.1
2	Quản lý an toàn máy chủ và ứng dụng	5.1.5.2	6.1.5.2	7.1.5.2
3	Quản lý an toàn dữ liệu	5.1.5.3	6.1.5.3	7.1.5.3
4	Quản lý an toàn thiết bị đầu cuối	Không yêu cầu	Không yêu cầu	7.1.5.4
5	Quản lý phòng chống phần mềm độc hại	Không yêu cầu	Không yêu cầu	7.1.5.5
6	Quản lý giám sát an toàn hệ thống thông tin	Không yêu cầu	Không yêu cầu	7.1.5.6
7	Quản lý điểm yếu an toàn thông tin	Không yêu cầu	Không yêu cầu	7.1.5.7
8	Quản lý sự cố an toàn thông tin	Không yêu cầu	6.1.5.4	7.1.5.8
9	Quản lý an toàn người sử dụng đầu cuối	Không yêu cầu	6.1.5.5	7.1.5.9

1.6. Phương án Quản lý rủi ro an toàn thông tin

Phương án quản lý rủi ro an toàn thông tin cần bao gồm các thành phần sau: (1) định mức rủi ro chấp nhận được đối với hệ thống thông tin; (2) quy trình đánh giá và quản lý rủi ro an toàn thông tin và (3) các biện pháp kiểm soát và giảm thiểu rủi ro.

1.7. Phương án Kết thúc vận hành, khai thác, thanh lý, hủy bỏ

Phương án kết thúc vận hành, khai thác, thanh lý, hủy bỏ HTTT cần làm rõ các vấn đề sau: (1) quy định về bảo đảm an toàn thông tin trong quá trình kết thúc vận hành, khai thác, thanh lý hoặc hủy bỏ hệ thống; (2) quy trình xử lý thông tin khi thay đổi mục đích sử dụng hoặc khi tiến hành gỡ bỏ hệ thống và (3) phương án kỹ thuật thực hiện việc xử lý thông tin khi thay đổi mục đích sử dụng hoặc gỡ bỏ hệ thống.

2. Thuyết minh phương án bảo đảm an toàn thông tin về kỹ thuật

Yêu cầu an toàn cơ bản trong Thông tư 12/2022/TT-BTTTT và tiêu chuẩn quốc gia TCVN 11930:2017 là yêu cầu cơ bản và phù hợp với loại hình HTTT của đơn vị. Do đó, đối với các HTTT có đặc thù riêng, tùy thuộc vào đặc trưng của từng hệ thống cụ thể, việc thuyết minh phương án bảo đảm an toàn thông tin có thể thuyết minh cho phù hợp với đặc thù của hệ thống đó.

2.1. Thiết kế hệ thống

- Liệt kê, mô tả thiết kế các vùng mạng trong hệ thống theo chức năng, các vùng mạng.

- Thuyết minh phương án thiết kế bảo đảm các yêu cầu tương ứng theo từng cấp độ, cụ thể như sau:

- + Phương án quản lý truy cập, quản trị hệ thống từ xa an toàn: Mô tả thiết kế hệ thống mạng sử dụng thiết bị chuyên dụng hay thiết lập cấu hình chức năng bảo mật trên hệ thống hoặc phương án tương đương khác nếu có để bảo đảm việc truy cập, quản trị hệ thống từ xa an toàn.

- + Phương án quản lý truy cập giữa các vùng mạng và phòng chống xâm nhập: Mô tả thiết kế hệ thống mạng sử dụng thiết bị tường lửa hoặc thiết bị có chức năng tương đương để quản lý truy cập và phòng chống xâm nhập giữa các vùng mạng.

- + Phương án cân bằng tải, dự phòng nóng cho các thiết bị mạng: Mô tả phương án thiết kế và triển khai các thiết bị mạng trong hệ thống để thực hiện chức năng cân bằng tải, dự phòng nóng.

- + Phương án bảo đảm an toàn cho máy chủ cơ sở dữ liệu: Mô tả phương án sử dụng thiết bị chuyên dụng như tường lửa cơ sở dữ liệu hay phương án tương đương để bảo đảm an toàn cho máy chủ cơ sở dữ liệu.

- + Có phương án chặn lọc phần mềm độc hại trên môi trường mạng: Mô tả phương án sử dụng thiết bị chuyên dụng hay chức năng trên thiết bị tường lửa hoặc phương án tương đương để phát hiện và ngăn chặn các hành vi mã độc trên môi trường mạng.

- + Phương án phòng chống tấn công từ chối dịch vụ: Mô tả phương án sử dụng giải pháp chuyên dụng hay thuê dịch vụ hoặc phương án tương đương khác để phòng chống tấn công từ chối dịch vụ cho hệ thống (chỉ yêu cầu đối với các hệ thống có kết nối mạng Internet).

+ Phương án giám sát hệ thống thông tin tập trung: Mô tả phương án sử dụng giải pháp chuyên dụng hay giải pháp tương đương khác để thực hiện giám sát hệ thống thông tin tập trung.

+ Phương án giám sát an toàn hệ thống thông tin tập trung: Mô tả phương án sử dụng giải pháp chuyên dụng hay giải pháp tương đương khác để thực hiện giám sát hoạt động của hệ thống mạng, bảo đảm tính sẵn sàng của hệ thống.

+ Phương án quản lý sao lưu dự phòng tập trung: Mô tả phương án quản lý sao lưu dự phòng tập trung sử dụng giải pháp chuyên dụng hoặc giải pháp tương đương sử dụng các giải pháp như SAN, NAS...

+ Phương án quản lý phần mềm phòng chống mã độc trên các máy chủ/máy tính người dùng tập trung: Mô tả phương án quản lý tập trung các phần mềm phòng chống độc hại được cài đặt trên các máy tính /máy chủ gửi sử dụng thông qua một máy chủ quản lý tập trung.

+ Phương án phòng, chống thất thoát dữ liệu: Mô tả phương án phòng, chống thất thoát dữ liệu sử dụng trong hệ thống.

+ Phương án duy trì ít nhất 02 kết nối mạng Internet từ các ISP sử dụng hạ tầng kết nối trong nước khác nhau (nếu hệ thống buộc phải có kết nối mạng Internet).

+ Phương án bảo đảm an toàn cho mạng không dây: Mô tả phương án bảo mật cho mạng không dây sử dụng giải pháp chuyên dụng hoặc việc thiết lập cấu hình bảo mật trên hệ thống để bảo đảm an toàn cho mạng không dây.

+ Phương án quản lý tài khoản đặc quyền: Mô tả phương án quản lý tài khoản đặc quyền cho phép quản lý tập trung việc xác thực, phân quyền, giám sát hành vi và các chức năng bảo mật khác để quản lý các tài khoản quản trị trong hệ thống.

+ Phương án dự phòng hệ thống ở vị trí địa lý khác nhau: Cung cấp thông tin ngắn gọn về hệ thống dự phòng như: ở vị trí địa lý nào? Chức năng chính của hệ thống dự phòng và nguyên lý hoạt động cơ bản của hệ thống để thực hiện chức năng dự phòng.

+ Phương án dự phòng cho kết nối mạng giữa hệ thống chính và hệ thống dự phòng: Mô tả phương án kết nối mạng giữa hệ thống chính và hệ thống dự phòng để thực hiện đồng bộ dữ liệu và dự phòng nóng khi hệ thống chính xảy ra sự cố.

2.2. Thiết lập và cấu hình hệ thống

2.2.1. Bảo đảm an toàn mạng

a) Kiểm soát truy cập từ bên ngoài mạng: Mô tả việc quản lý truy cập từ các mạng bên ngoài theo chiều đi vào hệ thống tới các máy chủ dịch vụ bên trong mạng.

b) Kiểm soát truy cập từ bên trong mạng: Mô tả phương án quản lý truy cập từ các máy tính/máy chủ bên trong mạng theo chiều đi ra các mạng bên ngoài và các mạng khác bên trong mạng.

c) Nhật ký hệ thống: Mô tả phương án quản lý nhật ký hệ thống (log) trên các thiết bị hệ thống về bật chức năng ghi log; thông tin ghi log; thời gian, dung lượng ghi log; quản lý log.

d) Phòng chống xâm nhập: Mô tả phương án triển khai/thiết lập cấu hình của thiết bị phòng, chống xâm nhập IDS/IPS hoặc chức năng IDS/IPS trên thiết bị tường lửa có trong hệ thống nhằm đáp ứng yêu cầu an toàn.

đ) Phòng chống phần mềm độc hại trên môi trường mạng: Mô tả phương án triển khai/thiết lập cấu hình của thiết bị để thực hiện chức năng phòng chống phần mềm độc hại trên môi trường mạng đáp ứng yêu cầu an toàn.

e) Bảo vệ thiết bị hệ thống: Mô tả phương án triển khai/thiết lập cấu hình chức năng bảo mật trên các thiết bị có trong hệ thống nhằm bảo đảm bảo đảm an toàn cho thiết bị trong quá trình sử dụng và quản lý vận hành.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Kiểm soát truy cập từ bên ngoài mạng	5.2.1.2	6.2.1.2	7.2.1.2
2	Kiểm soát truy cập từ bên trong mạng	Không yêu cầu	6.2.1.3	7.2.1.3
3	Nhật ký hệ thống	5.2.1.3	6.2.1.4	7.2.1.4
4	Phòng chống xâm nhập	5.2.1.4	6.2.1.5	7.2.1.5
5	Phòng chống phần mềm độc hại trên môi trường mạng	Không yêu cầu	Không yêu cầu	7.2.1.6
6	Bảo vệ thiết bị hệ thống	5.2.1.5	6.2.1.6	7.2.1.7

2.2.2 Bảo đảm an toàn máy chủ

a) Xác thực: Mô tả việc cấu hình/thiết lập chính sách xác thực trên máy chủ để bảo đảm việc xác thực khi đăng nhập vào máy chủ an toàn.

b) Kiểm soát truy cập: Mô tả việc cấu hình/thiết lập chính sách kiểm soát truy cập trên máy chủ để bảo đảm việc truy cập, sử dụng máy chủ an toàn sau khi đăng nhập thành công.

c) Nhật ký hệ thống: Mô tả phương án quản lý nhật ký hệ thống (log) trên các máy chủ về: Bất chức năng ghi log; Thông tin ghi log; Thời gian, Dung lượng ghi log; Quản lý log.

d) Phòng chống xâm nhập: Mô tả việc cấu hình/thiết lập cấu hình bảo mật trên máy chủ để bảo vệ tấn công xâm nhập từ bên ngoài.

đ) Phòng chống phần mềm độc hại: Mô tả việc cấu hình/thiết lập cấu hình bảo mật trên máy chủ về: Cài đặt phần mềm phòng chống mã độc; Dò quét mã độc; Xử lý mã độc; Quản lý tập trung phần mềm phòng chống mã độc...để phòng chống mã độc cho máy chủ.

e) Xử lý máy chủ khi chuyển giao: Mô tả phương án xóa sạch dữ liệu; sao lưu dự phòng dữ liệu khi chuyển giao hoặc thay đổi mục đích sử dụng.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Xác thực	5.2.2.1	6.2.2.1	7.2.2.1
2	Kiểm soát truy cập	5.2.2.2	6.2.2.2	7.2.2.2
3	Nhật ký hệ thống	5.2.2.3	6.2.2.3	7.2.2.3
4	Phòng chống xâm nhập	5.2.2.4	6.2.2.4	7.2.2.4
5	Phòng chống phần mềm độc hại	5.2.2.5	6.2.2.5	7.2.2.5
6	Xử lý máy chủ khi chuyển giao	Không yêu cầu	6.2.2.6	7.2.2.6

3) Bảo đảm an toàn ứng dụng

a) Xác thực: Mô tả việc cấu hình/thiết lập chính sách xác thực trên ứng dụng để bảo đảm việc xác thực khi đăng nhập vào máy chủ an toàn.

b) Kiểm soát truy cập: Mô tả việc cấu hình/thiết lập chính sách kiểm soát truy cập trên ứng dụng để bảo đảm việc truy cập, sử dụng ứng dụng an toàn sau khi đăng nhập thành công.

c) Nhật ký hệ thống: Mô tả phương án quản lý nhật ký hệ thống (log) trên các ứng dụng về: Bất chức năng ghi log; Thông tin ghi log; Thời gian, dung lượng ghi log; Quản lý log.

d) Bảo mật thông tin liên lạc: Mô tả phương án mã hóa và sử dụng giao thức mạng hoặc kênh kết nối mạng an toàn khi trao đổi dữ liệu qua môi trường mạng.

đ) Chống chối bỏ: Mô tả phương án sử dụng và bảo vệ chữ ký số để bảo vệ tính bí mật và chống chối bỏ khi gửi/nhận thông tin quan trọng qua mạng.

e) An toàn ứng dụng và mã nguồn: Mô tả phương án cấu hình/thiết lập chức năng bảo mật cho ứng dụng và phương án bảo vệ mã nguồn ứng dụng.

Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Xác thực	5.2.3.1	6.2.3.1	7.2.3.1
2	Kiểm soát truy cập	5.2.3.2	6.2.3.2	7.2.3.2
3	Nhật ký hệ thống	5.2.3.3	6.2.3.3	7.2.3.3
4	Bảo mật thông tin liên lạc	Không yêu cầu	Không yêu cầu	7.2.3.4
5	Chống chối bỏ	Không yêu cầu	Không yêu cầu	7.2.3.5
6	An toàn ứng dụng và mã nguồn	Không yêu cầu	6.2.3.4	7.2.3.6

4) Bảo đảm an toàn dữ liệu

a) Nguyên vẹn dữ liệu: Mô tả phương án lưu trữ, quản lý thay đổi, khôi phục dữ liệu bảo đảm tính nguyên vẹn của dữ liệu.

b) Bảo mật dữ liệu: Mô tả phương án lưu trữ, quản lý thay đổi, khôi phục dữ liệu bảo đảm tính bí mật của dữ liệu.

c) Sao lưu dự phòng: Mô tả phương án sao lưu dự phòng dữ liệu; Các thông tin yêu cầu sao lưu dự phòng; Phân loại dữ liệu sao lưu dự phòng; Hệ thống sao lưu dự phòng...

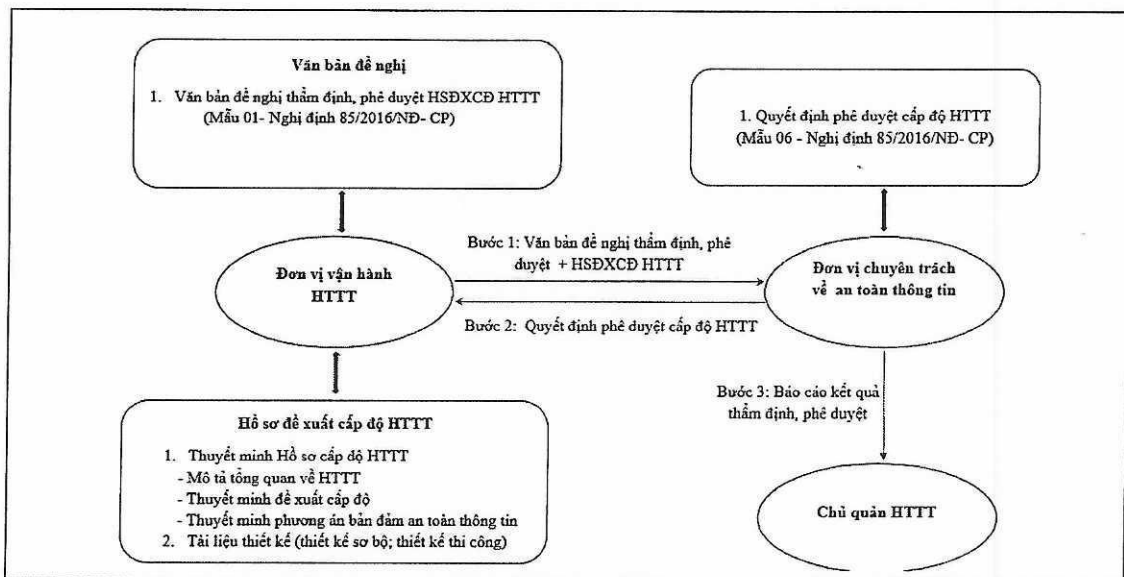
Bảng thể hiện mối liên hệ giữa các cấp độ đề xuất (từ cấp độ 1 đến cấp độ 3) của HTTT với các mục yêu cầu an toàn tương ứng trong tiêu chuẩn TCVN 11930:2017

TT	Yêu cầu	TCVN 11930:2017		
		Cấp độ 1	Cấp độ 2	Cấp độ 3
1	Nguyên vẹn dữ liệu	Không yêu cầu	Không yêu cầu	7.2.4.1
2	Bảo mật dữ liệu	Không yêu cầu	6.2.4.1	7.2.4.2
3	Sao lưu dự phòng	5.2.4.1	6.2.4.2	7.2.4.3

Phụ lục III**HƯỚNG DẪN CÁC BƯỚC THẨM ĐỊNH, PHÊ DUYỆT HỒ SƠ ĐỀ XUẤT CẤP ĐỘ HTTT**

(Kèm theo Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng của ĐHĐN được ban hành kèm theo Quyết định số 2453 ngày 26/6/2025 của Giám đốc ĐHĐN)

Thẩm quyền, quy trình, thủ tục xác định cấp độ an toàn HTTT được quy định từ Điều 12 đến Điều 18 Nghị định 85/2016/NĐ-CP. Dưới đây là hướng dẫn chi tiết các bước thẩm định, phê duyệt hồ sơ đề xuất cấp độ (HSĐXCĐ) HTTT (từ cấp độ 1 đến cấp độ 3).

1. Các bước đề xuất HTTT cấp độ 1 hoặc cấp độ 2

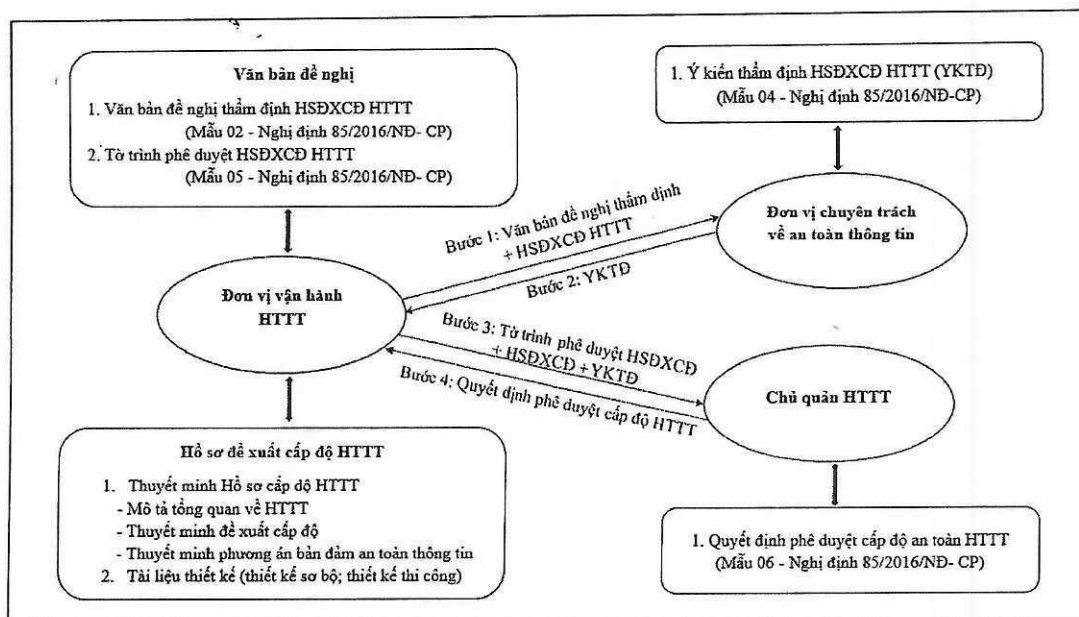
Hình 1: Hệ thống thông tin đề xuất cấp độ 1 hoặc cấp độ 2

Các bước thực hiện đề xuất HTTT cấp độ 1 hoặc cấp độ 2

TT	Nội dung	Biểu mẫu	Đơn vị thực hiện
Bước 1	Chuẩn bị và gửi HSĐXCĐ đến đơn vị chuyên trách về an toàn thông tin, hồ sơ bao gồm các tài liệu sau: (1) Văn bản đề nghị thẩm định, phê duyệt HSĐXCĐ; (2) Hồ sơ đề xuất cấp độ.	(1) Theo mẫu số 01 phụ lục kèm theo Nghị định 85/2016/NĐ-CP; (2) Theo Điều 15 của Nghị định 85/2016/NĐ-CP.	Đơn vị vận hành HTTT
Bước 2	<i>Thẩm định và phê duyệt HSĐXCĐ</i> Trong vòng 15 ngày kể từ ngày nhận đủ hồ sơ hợp lệ, đơn vị chuyên trách về an toàn thông tin có ý kiến thẩm định và phê duyệt HSĐXCĐ.	Theo mẫu số 06 phụ lục kèm theo của Nghị định 85/2016/NĐ-CP.	Đơn vị chuyên trách về an toàn thông tin

Bước 3	<i>Báo cáo kết quả thẩm định và phê duyệt HSDXCĐ</i> Đơn vị chuyên trách về an toàn thông tin gửi báo cáo kết quả thẩm định và phê duyệt HSDXCĐ đến Chủ quản HTTT.	Đơn vị chuyên trách về an toàn thông tin
--------	---	--

2. Các bước đề xuất HTTT cấp độ 3



Hình 2: Hệ thống thông tin đề xuất cấp độ 3

Các bước thực hiện đề xuất HTTT cấp độ 3

TT	Nội dung	Biểu mẫu	Đơn vị thực hiện
Bước 1	Chuẩn bị và gửi HSDXCĐ đến đơn vị chuyên trách về an toàn thông tin, hồ sơ bao gồm các tài liệu sau: (1) Văn bản đề nghị thẩm định HSDXCĐ; (2) Hồ sơ đề xuất cấp độ.	(1) Theo mẫu số 02 phụ lục kèm theo Nghị định 85/2016/ND-CP; (2) Theo Điều 15 của Nghị định 85/2016/ND-CP;	Đơn vị vận hành HTTT
Bước 2	<i>Thẩm định HSDXCĐ</i> Trong vòng 15 kể từ ngày nhận đủ hồ sơ hợp lệ, đơn vị chuyên trách về an toàn thông tin có ý kiến thẩm định HSDXCĐ.	Theo mẫu số 04 phụ lục kèm theo Nghị định 85/2016/ND-CP.	Đơn vị chuyên trách về an toàn thông tin

Bước 3	<i>Chuẩn bị và gửi HSĐXCĐ đến Chủ quản HTT để trình phê duyệt</i> (1) Tờ trình phê duyệt cấp độ HSĐXCĐ (2) HSĐXCĐ (đã chỉnh sửa sau khi có YKTĐ) (3) Ý kiến thẩm định HSĐXCĐ.	(1) Theo mẫu số 05 phụ lục kèm theo Nghị định 85/2016/NĐ-CP.	Đơn vị vận hành HTTT
Bước 4	Trong thời hạn 7 ngày làm việc, căn cứ vào ý kiến thẩm định của đơn vị chuyên trách về an toàn thông tin, Chủ quản HTTT phê duyệt hoặc yêu cầu Đơn vị vận hành HTTT sửa đổi bổ sung HSĐXCĐ theo thẩm quyền. Trường hợp HSĐXCĐ đạt yêu cầu theo quy định, Chủ quản HTTT phê duyệt cấp độ an toàn HTTT.	Theo mẫu số 06 phụ lục kèm theo Nghị định 85/2016/NĐ-CP.	Chủ quản HTTT

Trường hợp đơn vị chuyên trách về an toàn thông tin, đồng thời được chủ quản HTTT giao quản lý, vận hành HTTT, việc tổ chức thẩm định HSĐXCĐ được thực hiện theo một trong các phương án sau đây:

- Đơn vị chuyên trách về an toàn thông tin trình chủ quản HTTT giao một đơn vị trực thuộc có đủ năng lực chủ trì, tổ chức thẩm định.

- Đơn vị chuyên trách về an toàn thông tin trình chủ quản HTTT thành lập Hội đồng thẩm định độc lập thực hiện nhiệm vụ thẩm định HSĐXCĐ.

Phụ lục IV

HƯỚNG DẪN THẨM ĐỊNH HỒ SƠ ĐỀ XUẤT CẤP ĐỘ HTTT

(Kèm theo Quy chế bảo đảm an toàn thông tin mạng và an ninh mạng của ĐHĐN được ban hành kèm theo Quyết định số 2453 ngày 26/..6./2025 của Giám đốc ĐHĐN)

1. Thẩm định tính hợp lệ của Hồ sơ

Căn cứ quy định tại Điều 15 Nghị định số 85/2016/NĐ-CP, HSĐXCĐ phải bảo đảm đầy đủ nội dung và tài liệu theo quy định. Đơn vị thẩm định có trách nhiệm kiểm tra, đánh giá việc đáp ứng các yêu cầu sau:

1.1. Tài liệu thiết kế

Tài liệu thiết kế trong hồ sơ được xác định như sau:

- Đối với dự án đầu tư xây dựng mới hoặc dự án mở rộng, nâng cấp hệ thống thông tin: Hồ sơ phải có thiết kế sơ bộ hoặc tài liệu có giá trị tương đương.

- Đối với hệ thống thông tin đang vận hành: Hồ sơ phải có thiết kế thi công đã được cấp có thẩm quyền phê duyệt hoặc tài liệu có giá trị tương đương.

1.2. Thuyết minh HSĐXCĐ

1) Tài liệu thuyết minh HSĐXCĐ, bao gồm các nội dung chính sau:

- Mô tả tổng quan về hệ thống thông tin.
- Thuyết minh đề xuất cấp độ.
- Thuyết minh phương án bảo đảm an toàn hệ thống thông tin theo cấp độ.

2) Thuyết minh về việc đề xuất cấp độ căn cứ trên các tiêu chí theo quy định của pháp luật.

3) Thuyết minh phương án bảo đảm an toàn thông tin theo cấp độ tương ứng.

2. Thẩm định sự phù hợp về việc đề xuất cấp độ

Đơn vị thẩm định căn cứ vào nội dung thuyết minh mô tả tổng quan và đặc điểm của hệ thống thông tin để xác định phạm vi, quy mô và tính chất của hệ thống. Căn cứ vào nội dung thuyết minh đề xuất cấp độ, đối chiếu với:

- Khoản 1, Điều 6 Nghị định số 85/2016/NĐ-CP để xác định loại thông tin mà hệ thống xử lý.

- Khoản 2, Điều 6 Nghị định số 85/2016/NĐ-CP và Điều 7 Thông tư 12/2022/TT-BTTTT để xác định loại hình hệ thống.

- Các tiêu chí xác định cấp độ an toàn thông tin quy định tại Điều 7 đến Điều 11 Nghị định số 85/2016/NĐ-CP.

Trên cơ sở đó, đơn vị thẩm định đánh giá tính phù hợp của cấp độ an toàn thông tin được đề xuất.

3. Thẩm định sự phù hợp của phương án bảo đảm an toàn thông tin

Sự phù hợp của phương án bảo đảm an toàn thông tin là việc đánh giá nội dung thuyết minh trong HSĐXCĐ nhằm xác định mức độ đáp ứng các yêu cầu về bảo đảm an toàn thông tin. Tại thời điểm thẩm định, không bắt buộc tất cả các yêu cầu an toàn

phải được đáp ứng đầy đủ. Tuy nhiên, đối với các yêu cầu an toàn chưa đáp ứng hoặc dự kiến sẽ được đáp ứng trong tương lai (đối với hệ thống đang xây dựng), HSĐXCĐ cần nêu rõ phương án, kế hoạch cụ thể để triển khai các biện pháp đáp ứng các yêu cầu này.

Đối với yêu cầu an toàn về quản lý: Đơn vị thẩm định kiểm tra nội dung thuyết minh trong HSĐXCĐ để xác định hệ thống đã có chính sách, quy định nội bộ (có thể dưới dạng quy chế bảo đảm an toàn thông tin) đáp ứng các yêu cầu an toàn quản lý hay chưa. Trường hợp đã đáp ứng, cần xác định các văn bản hiện hành đã ban hành chính sách đó. Trường hợp chưa đáp ứng, HSĐXCĐ phải có phương án, kế hoạch sửa đổi, bổ sung hoặc xây dựng mới các quy chế, chính sách nhằm đáp ứng yêu cầu quản lý theo quy định.

Đối với yêu cầu an toàn về kỹ thuật: Đơn vị thẩm định kiểm tra nội dung thuyết minh trong HSĐXCĐ về phương án thiết kế, thiết lập, cấu hình hệ thống để đánh giá khả năng đáp ứng các yêu cầu kỹ thuật đặt ra. Trường hợp đã đáp ứng, cần làm rõ nội dung thiết lập cụ thể, các thiết bị được sử dụng và các yêu cầu kỹ thuật tương ứng. Trường hợp chưa đáp ứng, HSĐXCĐ phải thể hiện rõ phương án hoặc kế hoạch nâng cấp, điều chỉnh nhằm đảm bảo phù hợp với các yêu cầu kỹ thuật.

Việc thuyết minh phương án bảo đảm an toàn thông tin trong HSĐXCĐ theo đúng nội dung tiêu chuẩn quốc gia TCVN 11930:2017 được xem là đáp ứng đầy đủ các yêu cầu bắt buộc theo Thông tư 12/2022/TT-BTTTT. Phương án bảo đảm an toàn thông tin được trình bày trong HSĐXCĐ phải đảm bảo tính thống nhất, đồng bộ và phù hợp với thông tin, cấu trúc và giải pháp kỹ thuật trong tài liệu thiết kế. Mỗi yêu cầu an toàn đưa ra cần được thuyết minh rõ ràng, cụ thể tương ứng với giải pháp đề xuất, bảo đảm tính khả thi và phù hợp với quy định hiện hành.